



미래를 밝히는 눈,
동행의 발걸음, 감사실

특정감사

「LLM 기반 IT 관리실태 및 IT 응용통제」 특정감사 결과보고서

2025. 11.



한국전력기술 주식회사
감 사 실

목 차

I	감사 실시 개요	1
1.	감사 배경 및 목적	1
2.	감사 중점사항, 대상 및 범위	3
3.	감사 기간 및 인원	4
4.	감사 실시 과정	6
5.	AI (LLM 및 빅데이터 분석) 기술 활용	9
II	감사 대상 현황	19
1.	감사 대상 조직 및 인력	19
2.	회사 정보시스템 현황	20
III	감사 결과	26
1.	감사 결과 총평	26
2.	지적사항 총괄	27
3.	주요 문제점	27
IV	처분요구사항 일람표	29
V	감사결과 처분요구서	별첨
1.	정보화사업 과업 내용과 범위 설정 부적정	
2.	미사용 정보시스템 및 메뉴에 대한 운영관리 미흡	
3.	전사적 관점의 정보화기본계획 수립 미흡	
4.	♣ 시스템 본부권한 담당자의 조회 및 관리 권한 부적정	
5.	◆ 시스템 신입 및 퇴직자 권한관리 부적정	
6.	◆ 시스템 보안등급 관리 부적정	

I. 감사 실시 개요

1. 감사 배경 및 목적

정부는 국가 경쟁력의 핵심 인프라로 인공지능(AI)과 디지털 기술을 지정하고, 새 정부 출범과 동시에 ‘AI 기본사회 실현’을 주요 국정 추진과제로 설정하였다. 특히 공공기관의 AI를 활용한 정보시스템 고도화와 데이터 기반 의사결정체계 구축을 적극 지원하고 있으며, 이러한 정책 기조 아래 공공기관은 단순한 정보화 수준을 넘어, AI·빅데이터 등 신기술을 접목한 업무 자동화 및 지능화를 통해 행정의 효율성, 정확성 및 보안성을 동시에 확보해야 할 책임을 부여받고 있다.

한편, 최근 공공·민간 부문에서 잇따라 발생하고 있는 IT²⁾ 보안사고 및 시스템 품질 관리 문제는 정보시스템의 통제 미흡이 국민의 신뢰 훼손과 기관 운영 리스크로 직결될 수 있음을 명확히 보여주고 있다. 이에 따라 회사는 국가 핵심 인프라인 원자력 발전소 설계를 담당하는 기관으로서, 주요 정보시스템의 내부통제 체계를 점검하고, 사전에 취약점을 식별·해소하기 위한 선제적 감사의 필요성이 더욱 강조되고 있다.

특히, 0000년도 회사 전사 리스크 프로파일에 따르면 IT 및 보안 관련 중위험 이상의 리스크는 총 00건으로 집계되었으며, 이 중 적기에 점검이 필요한 주요 위험 요인으로는 △프로그램 접근 및 권한관리 △PC접근 및 정보보호 관리 △정보화 계획수립 미흡 및 산출물 관리 부적정 △시스템 구축·변경 시 타당성 검토 부족 등 0건(00%)이 식별되었다. 이러한 리스크는 설계정보 등 기관의 핵심 정보자산과 밀접하게 연관되어 있어 내부통제가 미흡할 경우 정보 유출, 시스템 장애, 데이터 왜곡 등의 중대한 경영 리스크로 확산될 가능성이 매우 높다. 또한, 응용시스템 내 입력, 처리, 출력 등 주요

1) 인공지능(Artificial Intelligence, AI) : 인간의 지능을 모방하도록 설계된 컴퓨터 시스템 또는 소프트웨어의 능력을 의미

2) IT(Information Technology) : 정보를 생성, 저장, 전송, 처리, 관리하기 위해 컴퓨터, 네트워크, 소프트웨어, 하드웨어 등의 기술을 활용하는 분야

업무 프로세스에 대한 통제(응용통제)가 미흡할 경우, 시스템의 데이터 무결성과 신뢰성은 근본적으로 훼손될 수 있으며, 이는 결과적으로 잘못된 의사결정이나 업무 오류로 이어질 수 있다. 따라서 응용통제의 설계 적정성과 운영 실효성 점검은 단순한 시스템 검토를 넘어, 조직의 핵심 업무 신뢰성과 경영 리스크 관리 측면에서 매우 중요한 의미를 갖는다.

이러한 배경 아래, 감사실은 정부 정책기조에 선제적으로 부응하고 ‘IT 기반 감사’로의 전환을 위한 0000년 말 「IT기반 감사 추진계획」(0000.00.00.)³⁾ 수립하였으며, 이를 통해 IT 거버넌스, IT프로젝트, 정보시스템 운영, 정보보안 분야의 IT RCM을 마련한 바 있다. 이러한 IT감사 로드맵에 따라 2024년에는 「ICT⁴⁾분야 업무추진실태 특정감사」⁵⁾를 실시하여 IT 일반통제 영역의 개선과제를 도출하였다. 이와 연계하여, 2025년은 IT감사 로드맵 2개년 차인 ‘정착기’에 진입하는 중요한 시점으로, 감사실은 기관 최초로 IT감사 범위를 응용통제⁶⁾ 영역으로 확장하고자 한다.

이번 감사에서는 RAG⁷⁾ 기반 LLM⁸⁾ 시스템을 활용하여 IT 취약분야에 대한 착안사항을 도출하는 등 AI 기반의 감사 고도화 방향을 실무에 적용하여 IT 관리실태 점검하고, IT 응용통제 관련하여 실제 업무 프로세스 내 자동화된 통제가 적절하게 설계·운영되는지를 검증하고 회사 주요 業인 설계 관련 시스템을 대상으로 프로세스의 통제 타당성과 일관성, 데이터 정확성 및 완전성을 종합적으로 살펴보았다. 이러한 접근은 단순한 기술 도입을 넘어 감사 패러다임의 전환을 의미하며, 향후 지능형 감사 체계의 정착과 확산을 위한 실질적인 기반을 마련한다는 점에서 의미가 있다.

3) 감사실-0000 (0000.00.00.) “IT기반 감사 추진계획(안)”

4) ICT(Information and Communications Technology)는 정보 기술(IT)과 통신 기술(CT)을 통합한 개념으로, 정보의 생성, 저장, 처리, 전송, 공유를 디지털 기술을 통해 효율적으로 수행하는 모든 기술과 시스템

5) 감사실-0000 (0000.00.0.) “「ICT분야 업무추진실태」 특정감사 결과 승인”

6) IT 통제는 IT 일반통제와 IT 응용통제로 나뉘며, IT 응용통제는 응용프로그램 레벨에서 데이터의 입력 및 변조 등의 사항이 신뢰성 있게 처리되고 있는지 확인하는 것이 주요 목적임

7) RAG(Retrieval-Augmented Generation, 검색증강생성) : 대규모 언어 모델(LLM)이 질문에 답변할 때, 외부 지식 소스(예: 문서, 데이터베이스, 위키 등)에서 관련 정보를 실시간으로 검색(Retrieval)한 후, 그 정보를 바탕으로 더 정확하고 사실에 기반한 답변을 생성(Generation)하도록 돕는 기술

8) LLM(Large Language Model, 대규모 언어 모델)은 거대한 양의 텍스트 데이터를 학습하여, 자연어를 이해하고, 생성하고, 질문에 답변하며, 글을 작성하거나 번역하는 능력을 갖춘 인공지능 모델, Chat GPT 기반 기술

2. 감사 중점사항, 대상 및 범위

이번 감사에서는 ♣실, ♠실, ♥실의 IT 관리실태 및 IT 응용통제 전반을 대상으로 감사를 실시하였으며, 감사 중점사항은 다음과 같다.

☐ 감사 중점사항

구 분	감사 중점사항	비 고
(생 략)		

☐ 감사 대상

- ♣실, ♥실, ♠실

☐ 감사 범위

- 데이터베이스 모델링 표준 준수 여부
- 정보시스템 운영 현황 적정성
- 신규 인터넷 PC 암호 설정 여부
- IT 응용통제

☐ 감사 대상 기간

- 2022.7.1. ~ 2025.6.30. (감사착수일 기준 최근 3년)

3. 감사 기간 및 인원

☐ 감사 기간: 2025.8.5.(화) ~ 9.5.(금) / 실 감사일 23일

※ 당초 감사기간은 2025.8.5.(화) ~ 8.29.(금)이었으나, 감사 과정에서 하계 휴가 등으로 피감부서 답변이 지연됨에 따라 감사기간 연장

☐ 주요 진행 일정

실적	주요 내용	비고
(생 략)		

□ 감사 인원 투입 내역

구분	감사인	주요 경력/자격	업무 분담	투입일수
반장	A ㄴ장	(생 략)		
반원	B ㄹ장			
	C ㄹ장			
	D ㄹ			
	E ㄹ			
	F ㅁ			
	G ㅁ			
계				

* 감사 중점사항 및 감사인 주요 경력을 고려하여 업무 분담

□ 외부 전문가 활용

○ 교차감사⁹⁾ : ♡발전 감사실 ㄹ부 J ㄹ장

- 「정보화업무절차」 제24조(정보시스템 운영성과 측정)에 따라서 미사용 메뉴의 사용률을 점검하여 사용하지 않는 메뉴를 정기적으로 점검하여 비활성화, 통합 등 적절한 개선 방안을 수립·시행하여야 함
- 한국전력기술의 ㄹ과 ▼시스템에서 미사용 메뉴를 확인하였고, 최근 3년 이내 사용률이 낮거나 미사용 중인 메뉴를 정리하는 것을 감사의견으로 제시

(생 략)

9) 감사실-000 (0000.00.00.) “교차감사 지원 협조 요청”, 감사실-0000 (0000.00.00.) “교차감사인 감사의견서 송부(♡발전)”

4. 감사 실시 과정

실지감사에 앞서 감사업무 협약 기관 벤치마킹을 통해 IT관련 타사 감사사례에 대한 학습 및 관련 자료를 수집·분석하였다. 또한, 회사 감사 대상 전반에 대한 이해를 제고하기 위해 예비감사(2025.7.2. ~ 7.15.)를 실시하였으며, 예비감사 결과 예상 문제점이 도출됨에 따라 2025.8.5.부터 9.5.까지 총 23일간 감사인원 7명을 투입하여 실지감사를 실시하였고, ♥발견과 교차감사를 실시하였다.

① 연간감사계획 수립
(생 략)



② 대내·외 사전 학습활동 실시
(생 략)



③ 예비감사 실시(2025.7.2. ~ 7.15.)

(생 략)



4 감사 실시(2025.8.5. ~ 9.5., 실감사일 23일)

(생 략)



⑤ 감사 종료 및 결과 통보

(생 략)



⑥ 감사결과 공개 및 결과 환류

(생 략)

(다 음 장 에 계 속)

5. [감사기법] AI (LLM 및 빅데이터 분석) 기술 활용

가. 개요

최근 감사 환경은 급변하는 디지털 기술과 복잡한 리스크 양상으로 인해 기존의 경험 기반 접근만으로는 한계에 직면하고 있다. 이에 따라, 감사의 객관성과 포괄성을 강화하고, 잠재 리스크를 조기에 식별하기 위해 인공지능(AI) 기반의 LLM과 빅데이터 분석 기술을 적극적으로 도입하는 것이 중요해졌다.

이러한 취지에서 감사실은 RAG기반 LLM을 활용한 감사착안사항 도출 프로세스를 구현하였다. AI기술을 감사에 적용하여 감사업무의 효율성을 제고하고, 타 기관의 과거 감사사례를 활용하여 데이터 기반의 감사착안사항을 체계적으로 제안할 수 있도록 하였다.

또한, 빅데이터 분석에는 오픈소스¹⁰⁾ 도구 Orange3를 활용하여 감사 데이터를 분석하였다. Orange3는 시각적 워크플로우¹¹⁾ 기반의 분석 환경을 제공하여 비전문가도 직관적으로 데이터를 조작하고 분석할 수 있다는 장점이 있다. 본 감사에서 퇴직직원의 퇴직일과 권한회수일 간의 기간 차이를 Orange3로 시각화하는 등 빅데이터 분석을 수행하여 시스템 사용자 권한 관리의 비정상적인 패턴을 효과적으로 탐지하였다.

나. RAG기반 LLM을 활용한 감사착안사항 도출 프로세스

RAG 기반 LLM을 활용한 감사착안사항 도출 프로세스는 알리오(ALIO¹²⁾, 공공기관 정보공개포털)에서 공개한 감사보고서를 사용함으로써, 기존 LLM 모델의 한계를 극복하고 최신 감사사례를 반영하여 감사착안사항을 도출하는 데 목적이 있다. [그림 1]과 같이 총 5단계의 프로세스로 ①알리오에서 감사보고서

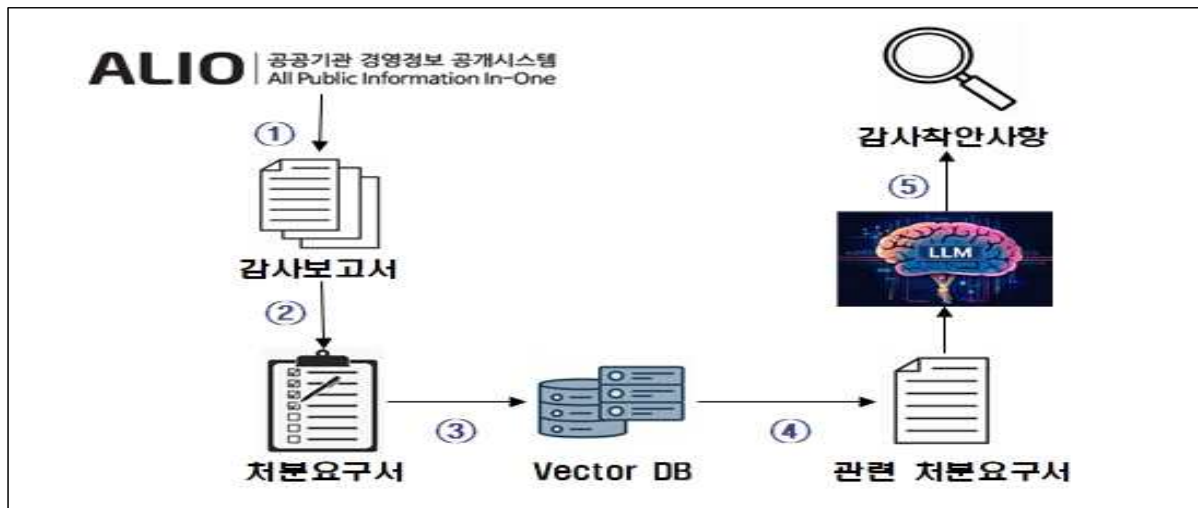
10) Orange3 : www.orangedatamining.com, 데이터 마이닝 프로그래밍

11) 워크플로우(Workflow) : 특정 업무나 프로세스를 구성하는 일련의 작업 단계(Tasks)가 어떤 순서로, 누가, 어떻게 수행되는지를 체계적으로 정의한 흐름

12) 알리오(ALIO) : www.alio.go.kr

수집 ②감사보고서에서 처분요구서 정리 ③처분요구서 벡터 데이터베이스¹³⁾ 저장 ④RCM 선정 및 질의 생성 ⑤ LLM 질의를 통한 감사착안사항 도출 프로세스로 진행하였다. 이를 통해 실제 사례에 기반한 맥락 인식과 정확한 정보 제시가 가능한 RAG 환경을 구현함으로써, 감사 착안의 객관성과 신뢰성을 제고하였다.

[그림 1] LLM을 활용한 감사착안사항 도출 과정



1) 감사보고서 수집

알리오의 공공기관 경영정보 공개시스템으로, [그림 2]와 같이 내부·외부감사결과 검색창에서 “IT”, “정보화사업”, “정보보안” 등 관련 키워드 기반으로 검색을 수행하였다. 2018년부터 2025년까지의 자료를 대상으로 수집한 결과 [그림 3]과 같이 총 101건의 IT 관련 감사보고서를 확보하였다.

[그림 2] 알리오 공개 감사보고서 조회



13) 벡터 데이터베이스(Vector Database) : 비정형 데이터를 다차원의 좌표로 표시하는 저장소, 텍스트/이미지/영상/음성과 같은 다양한 형태의 비정형 데이터를 컴퓨터가 이해하고 처리할 수 있도록 수치 형태로 변환하는 기술

[그림 3] 확보된 IT 관련 감사보고서 목록

경북대학교치과병원_2023년_전산 및 정보보안, 홍보분야 감사결과보고서.pdf	2025-04-22 오전 11:05	PDF 파일	148KB
공무원연금공단_2019년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	2025-04-22 오전 11:17	PDF 파일	1,721KB
공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	2025-04-22 오전 11:15	PDF 파일	2,087KB
공무원연금공단_2021년_개인정보 및 정보보안 감사 결과.pdf	2025-04-22 오전 11:11	PDF 파일	2,414KB
공무원연금공단_2022년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	2025-04-22 오전 11:09	PDF 파일	1,371KB
공무원연금공단_2023년_개인정보 및 정보보안 관리실태 특정감사 결과보고서.pdf	2025-04-22 오전 11:03	PDF 파일	1,693KB
공무원연금공단_2024년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	2025-04-22 오전 10:59	PDF 파일	913KB
국립공원공단_2023년_정보시스템(it) 특정감사 결과보고서.pdf	2025-04-22 오전 10:31	PDF 파일	518KB
국립공원공단_2024년_정보보안 특정감사 결과보고.pdf	2025-04-22 오전 11:01	PDF 파일	110KB
국립해양생물자원관_2022년_it분야 개인정보 관리 실태 점검결과.pdf	2025-04-28 오전 9:29	PDF 파일	89KB
국방과학연구소_2022년_사업 전산장비 도입 및 관리실태 특정감사보고서.pdf	2025-04-22 오전 11:21	PDF 파일	133KB
그랜드코리아레저_2024년_성과감사(카지노IT시스템 및 정보보안운영실태).pdf	2025-04-22 오전 10:26	PDF 파일	188KB
기술보증기금_2020년_ict운영부 감사결과.pdf	2025-04-22 오전 10:56	PDF 파일	86KB
대한석탄공사_2018년_it 정보보안 시스템 운영실태 특정감사 결과보고.pdf	2025-04-22 오전 11:38	PDF 파일	476KB
부산대학교병원_2024년_부산대학교병원 정보전산팀, 정보보안팀 정기감사결과.pdf	2025-04-22 오전 11:20	PDF 파일	146KB
부산대학교병원_2024년_양산부산대학교병원 정보전산팀, 정보보안팀 정기감사결과.pdf	2025-04-22 오전 11:20	PDF 파일	906KB
부산대학교치과병원_2022년_정보전산팀 종합감사 결과보고서.pdf	2025-04-22 오전 11:21	PDF 파일	232KB
사립학교교직원연금공단_2021년_연금운영 it감사 결과보고서.pdf	2025-04-28 오전 9:29	PDF 파일	783KB
사립학교교직원연금공단_2023년_전산시스템 운영관리 실태 감사 결과보고서(공시).pdf	2025-04-22 오전 11:21	PDF 파일	1,379KB
서울올림픽기념국민체육진흥공단_2023년_it(정보보안)감사 결과.pdf	2025-04-22 오전 11:03	PDF 파일	368KB
서울올림픽기념국민체육진흥공단_2024년_it(정보보안)감사 결과.pdf	2025-04-22 오전 10:29	PDF 파일	747KB
신용보증기금_2019년_자세대 정보시스템 구축 과제 관리 및 운영실태 점검.pdf	2025-04-22 오전 11:33	PDF 파일	184KB
신용보증기금_2020년_ict전략부 종합감사결과.pdf	2025-04-22 오전 10:56	PDF 파일	272KB
예금보험공사_2019년_it업무 추진실태 성과감사 결과.pdf	2025-04-22 오전 10:53	PDF 파일	604KB
예금보험공사_2022년_정보보호 및 정보보안 업무 추진실태 특정감사 결과.pdf	2025-04-22 오전 11:09	PDF 파일	1,158KB
예금보험공사_2023년_it전략운영부 종합감사 결과.pdf	2025-04-22 오전 10:30	PDF 파일	1,179KB
인천국제공항공사_2019년_업무지원용 it정보 시스템 활용실태 점검 특정감사 결과.pdf	2025-04-28 오전 9:21	PDF 파일	793KB
인천국제공항공사_2023년_제어시스템 정보보안 관리실태 특정감사 결과.pdf	2025-04-28 오전 9:17	PDF 파일	2,550KB
정보통신산업진흥원_2019년_자체감사결과(글로벌ict본부).pdf	2025-04-22 오전 10:57	PDF 파일	224KB
제주국제자유도시개발센터_2021년_정보시스템 특정감사 결과보고서.pdf	2025-04-28 오전 9:29	PDF 파일	902KB
제주국제자유도시개발센터_2024년_정보시스템 구축 및 운영 성과감사 결과보고서.pdf	2025-04-22 오전 11:26	PDF 파일	540KB
주택도시보증공사_2019년_정보보안 업무 추진 및 운영 실태 특정감사 결과보고서.pdf	2025-04-28 오전 9:29	PDF 파일	725KB
주택도시보증공사_2024년_사이버보안 특정감사 결과보고.pdf	2025-04-28 오전 9:29	PDF 파일	184KB
중소벤처기업진흥공단_2019년_주요 정보시스템 구축 및 운영실태 특정감사 결과보고.pdf	2025-04-22 오전 11:36	PDF 파일	1,379KB
코레일네트웍스_2019년_보안 관리실태 특정감사 공시자료.pdf	2025-04-28 오전 9:29	PDF 파일	80KB
코레일유통_2022년_전산시스템 고도화 운영실태 점검 특정감사 결과.pdf	2025-04-22 오전 11:30	PDF 파일	210KB
한국가스기술공사_2024년도 IT기반 업무처리실태 성과감사 결과.pdf	2025-04-22 오전 10:26	PDF 파일	272KB
한국가스안전공사_2018년_it분야 성과감사 결과보고서.pdf	2025-04-28 오전 9:29	PDF 파일	920KB
한국감정원_2019년_공시·통계 업무시스템 점검 특정감사 결과보고서.pdf	2025-04-22 오전 11:35	PDF 파일	563KB
한국건강가정진흥원_2019년_정보보안 개인정보보호 특정감사 결과.pdf	2025-04-22 오전 11:18	PDF 파일	147KB
한국건강가정진흥원_2020년_정보보안 개인정보보호 특정감사 결과보고.pdf	2025-04-22 오전 11:14	PDF 파일	150KB
한국건강가정진흥원_2021년_정보보안 개인정보보호 특정감사 결과보고서.pdf	2025-04-22 오전 11:12	PDF 파일	159KB

2) 감사보고서에서 처분요구서 정리

수집된 101건의 감사보고서는 PDF 또는 한글 문서 형식으로 제공되었으며, 각 감사보고서에 포함된 처분요구서를 중심으로 762건의 처분요구서를 추출하였다. 추출된 항목은 [그림 4]와 같이 공공기관명, 감사 연도, 감사명, 파일명, 처분요구, 처분 종류 등의 항목으로 정리하여, 분석에 적합한 구조화된 데이터로 재편성하였다.

[그림 4] 처분요구서를 분석에 적합한 구조화된 데이터로 재편성

순번	공공기관	년도	감사명	파일명	처분요구사항	처분종류
1	경북대학교지과병원	2023	전산 및 정보보안·홍보분야 감사결과보고서	경북대학교지과병원_2023년_전산 및 정보보안, 홍보분야 감사결과보고서.pdf	정보시스템 운영에 관한 건	권고
2	경북대학교지과병원	2023	전산 및 정보보안·홍보분야 감사결과보고서	경북대학교지과병원_2023년_전산 및 정보보안, 홍보분야 감사결과보고서.pdf	프로그램 개발(요청 후 지연처리)	권고
3	경북대학교지과병원	2023	전산 및 정보보안·홍보분야 감사결과보고서	경북대학교지과병원_2023년_전산 및 정보보안, 홍보분야 감사결과보고서.pdf	프로그램 개발(반려) 적정성 검토	권고
4	경북대학교지과병원	2023	전산 및 정보보안·홍보분야 감사결과보고서	경북대학교지과병원_2023년_전산 및 정보보안, 홍보분야 감사결과보고서.pdf	프로그램 개발(윤리) 관리	권고
5	경북대학교지과병원	2023	전산 및 정보보안·홍보분야 감사결과보고서	경북대학교지과병원_2023년_전산 및 정보보안, 홍보분야 감사결과보고서.pdf	프로그램 및 DB 백업요청관리 관련	개선
6	경북대학교지과병원	2023	전산 및 정보보안·홍보분야 감사결과보고서	경북대학교지과병원_2023년_전산 및 정보보안, 홍보분야 감사결과보고서.pdf	계약 요청 절차 미흡	개선
7	경북대학교지과병원	2023	전산 및 정보보안·홍보분야 감사결과보고서	경북대학교지과병원_2023년_전산 및 정보보안, 홍보분야 감사결과보고서.pdf	예산 절감 및 내원환자에 대한 서비스 개선에 기여	모범사례
8	공무원연금공단	2019	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2019년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	개인정보 수집·이용 및 제공 동의서 청구 미흡 및 표준 서식 마련 필요	주의, 권고
9	공무원연금공단	2019	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	출력을 실행해 예외기간 적용 잘못 및 정책 보안 필요	주의, 권고
10	공무원연금공단	2019	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	개인정보 처리업무 위탁관리 절차 미흡	시정
11	공무원연금공단	2019	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	비공개 대상 전자문서 관리 미흡	주의
12	공무원연금공단	2019	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	정보자산 변동입 관리대상 및 개인정보 파기관리대상 미확성	시정
13	공무원연금공단	2019	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	정보유출대응 시 보안강제 미실시	주의
14	공무원연금공단	2019	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	개인정보 처리방침의 홈페이지 공개 방법 부적합 및 현행화 필요	시정
15	공무원연금공단	2019	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	단말기(업무용 PC)에 대한 보안관리 미흡	시정
16	공무원연금공단	2019	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	보안프로그램 정책 미흡 및 보안점검 미실시	시정
17	공무원연금공단	2019	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	FTP 서비스 포트 관리 미흡	시정
18	공무원연금공단	2019	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	정보시스템 접근에 대한 사용자 계정 보안 관리 미흡	시정
19	공무원연금공단	2019	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	영상정보처리기기 운영 시스템 계정 비밀번호 관리 미흡	현지조치
20	공무원연금공단	2020	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	그룹웨어를 이용한 외부 메일 발송 시 사후승인 절차 관리 미흡	주의
21	공무원연금공단	2020	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	교육과 직원의 그룹웨어를 이용한 외부 메일 발송 시 사후승인 절차 관	주의, 홍보
22	공무원연금공단	2020	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	행정메일 의의결립 시 개별 파일 유·재원해당 신고신고서 미제출	주의
23	공무원연금공단	2020	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	파일무역을 이용하여 내부망 자료를 인터넷망 전송 시 사후승인 절차 관	개선
24	공무원연금공단	2020	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	업무영역 저장공간(V 드라이브) 내 비암호화 개인정보파일에 대한 보안	홍보
25	공무원연금공단	2020	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	자회사인 ***** 플리크 망 분리 사업추진 필요	권고
26	공무원연금공단	2020	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	영상정보처리기기(CCTV) 설치·운영 안내문 관리 미흡	시정
27	공무원연금공단	2020	개인정보 및 정보보안 관리실태 특정감사	공무원연금공단_2020년_개인정보 및 정보보안 관리실태 특정감사 결과보고.pdf	***** 문서고 제한구역 표지 미개시	시정

3) 처분요구서 벡터 데이터베이스 저장

알리오를 통해 수집한 101건의 감사보고서에서 추출·정제된 762건의 처분요구서를 [그림 5]와 같이 벡터 데이터베이스(Vector DB)에 저장함으로써, LLM이 질의에 응답할 때 최신 감사사례를 기반으로 한 정확한 답변을 생성할 수 있도록 하였다.

LLM은 자체학습 데이터에 최신 알리오 감사보고서가 포함되어 있지 않기 때문에, 실시간으로 외부의 관련 정보를 검색하고 참조할 수 있는 구조가 필요하다. 이를 위해 정제된 처분요구서 텍스트를 의미 기반으로 임베딩(Embedding)¹⁴⁾하여, 처분요구서를 고차원 벡터 공간에 매핑하였다. 이 과정을 통해 유사한 내용의 처분요구서는 벡터 공간에서 인접한 위치에 배치되며, LLM이 질의를 받았을 때 관련성이 높은 과거 사례를 효율적으로 검색(Retrieval)¹⁵⁾할 수 있게 된다.

본 감사에서는 벡터 데이터베이스를 활용하여 LLM의 질의 시점에서 유사도 기반 검색¹⁶⁾을 통해 관련 있는 사례를 상위 3개(Retrieval Top-K)로 추출하여, 답변 생성(Generation) 단계¹⁷⁾에서 질의에 맞는 감사착안사항을 도출하는 데 활용하였다.

14) 임베딩(Embedding) : 단어, 문장, 이미지, 사용자 행동 등의 복잡한 데이터를 숫자의 형태(벡터)로 변환하여, 컴퓨터가 의미를 이해하고 유사성을 계산할 수 있도록 만드는 고차원 수치 표현 기술

15) 임베딩된 데이터를 유사도 기반으로 검색

16) 유사도 기반 검색(Similarity-Based Search) : 단순히 키워드가 일치하는지 여부가 아니라, 쿼리(검색 요청)와 데이터 간의 의미적 유사도 또는 특징의 유사성을 기반으로 가장 비슷한 결과를 찾아주는 검색 방식

17) 조회된 감사처분요구서를 기반으로 LLM이 감사착안사항을 제안

[그림 5] 감사처분요구서의 벡터 데이터베이스 저장 정보

	A-Z id	collection_id	embedding	A-Z document	cmetadata
1	269d9a06-b923-4e24-9a1b-aac9e3b7f	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.004602918,-0.014376794,0.0064955	정보시스템 운영에 관한 건	["기관": "경북대학교치과병원", "년도":
2	bd7e1a7f-71e7-4c54-9284-66e275a77	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.0132004535,-0.038293965,-0.00512	프로그램 개발 관련(요청 후 지연처리)	["기관": "경북대학교치과병원", "년도":
3	57aa9abd-0c5f-4ef4-97d2-7eb9ee065	89b44584-d2ae-4ca0-a46a-d207b2ac	[0.009784246,-0.038008563,-0.0007315	프로그램 개발 관련(반려 적정성 검토)	["기관": "경북대학교치과병원", "년도":
4	387c6047-b960-49ab-9cd9-67c0e08b6	89b44584-d2ae-4ca0-a46a-d207b2ac	[0.0023257046,-0.046769146,-0.005977	프로그램 개발 관련(운영 관리)	["기관": "경북대학교치과병원", "년도":
5	40a048a7-8045-4191-935d-669b4963f	89b44584-d2ae-4ca0-a46a-d207b2ac	[0.0031135427,-0.044529792,-0.006746	프로그램 및 DB 배포요청관리 관련	["기관": "경북대학교치과병원", "년도":
6	b03acce-05a7-4039-a7db-fe47b6a2c	89b44584-d2ae-4ca0-a46a-d207b2ac	[0.0023286324,-0.0044402345,0.00956	계약 요청 절차 미흡	["기관": "경북대학교치과병원", "년도":
7	5db9685d-5fc5-4c84-8881-941c66d66	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.0012589165,-0.019279009,0.010064	예산 절감 및 내원환자에 대한 서비스	["기관": "경북대학교치과병원", "년도":
8	56a9c3c6-1b77-4856-ac66-c5b8ea321	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.00909388,0.004903304,0.03349821,	개인정보 수집·이용 및 제공 동의서 장	["기관": "공무원연금공단", "년도": 201
9	7a889573-f0d1-496e-865a-1059dco1	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.03248728,-0.020580875,-0.0040119	출력을 실명제 예외기간 적용 잘못 및	["기관": "공무원연금공단", "년도": 201
10	71e709b9-97ab-4ba9-b1e2-65c5f4c65	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.006273705,-0.0009988032,0.01849	개인정보 처리업무 위탁관리 절차 미준	["기관": "공무원연금공단", "년도": 201
11	241ca77e-5218-4241-9204-6a81f0078	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.019756839,-0.00015267984,0.00146	비공공 대상 전자문서 관리 미흡	["기관": "공무원연금공단", "년도": 201
12	17729277-a6f3-4e7e-96a4-401517681	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.016650593,-0.00090129516,0.00777	정보자산 반출 입 관리대상 및 개인정보	["기관": "공무원연금공단", "년도": 201
13	9312830b-9be6-4ade-9a2d-b0312264	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.013339681,-0.025777841,0.0061204	정보화용역사업 보안각서 미집구	["기관": "공무원연금공단", "년도": 201
14	b9dfd1d9-c433-4ff0-be14-9255f2af40	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.017183917,0.009819381,0.0179059	개인정보 처리방침의 홈페이지 공개 병	["기관": "공무원연금공단", "년도": 201
15	d288ccca-3f96-4a31-a363-f2075415bf	89b44584-d2ae-4ca0-a46a-d207b2ac	[0.0019078324,-0.026706241,0.014839	단말기(업무용 PC)에 대한 보안관리 미	["기관": "공무원연금공단", "년도": 201
16	740e80e4-c4ab-4d0f-9c03-7320f59ac	89b44584-d2ae-4ca0-a46a-d207b2ac	[0.00014113075,-0.029957695,-0.00716	보안프로그램 정책 미흡 및 보안점검 미	["기관": "공무원연금공단", "년도": 201
17	a6485608-8144-448e-b0d7-65113d15	89b44584-d2ae-4ca0-a46a-d207b2ac	[0.0057755625,-0.017124347,0.029392	FTP 서비스 포트 관리 미흡	["기관": "공무원연금공단", "년도": 201
18	1b0ac0bb-05a2-473a-9398-6df5fcd72	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.0013897335,-0.0029735023,0.01425	정보시스템 접근에 대한 사용자 계정	["기관": "공무원연금공단", "년도": 201
19	a9034465-c28a-462d-9b44-cbcdc17f	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.019317156,-0.0062668603,0.001474	영상정보처리기기 운영 시스템 계정 비	["기관": "공무원연금공단", "년도": 201
20	dea2f764-7fc3-4498-b7c2-f13c0a6f92	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.013599605,-0.012860028,-0.006430	그룹웨어를 이용한 외부 메일 발송 시	["기관": "공무원연금공단", "년도": 202
21	a9f93ae3-3972-49a9-8d0d-f8e9447c6	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.014268988,-0.0024488382,-0.01426	교육파견 직원의 그룹웨어를 이용한 외	["기관": "공무원연금공단", "년도": 202
22	af052d23-11d2-421d-8617-d2a717e9c	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.0419314,-0.040521707,-0.00404249	해킹메일 모의훈련 시 메일 열람 후 해	["기관": "공무원연금공단", "년도": 202
23	f347b019-41aa-4baf-a9b6-8b1f420a6	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.01948495,-0.01268966,-0.00714448	파일무결을 이용하여 내부망 자료를 인	["기관": "공무원연금공단", "년도": 202
24	a0854c55-9c49-43d0-86f1-39b108762	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.026013859,-0.03422876,0.01585476	업무영역 저장공간(V드라이브) 내 비	["기관": "공무원연금공단", "년도": 202
25	7214bcd7-141d-456a-9167-f792373b2	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.020819936,-0.012520556,0.0130992	자회사() 물리적 방화벽 사	["기관": "공무원연금공단", "년도": 202
26	84d173e3-b05a-4873-ada2-8ec575a5	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.014355599,-0.0020029477,9.458246	영상정보처리기기(CCTV) 설치·운영 인	["기관": "공무원연금공단", "년도": 202
27	64f332f3-3b3f-4a22-ad5a-806c57a8bf	89b44584-d2ae-4ca0-a46a-d207b2ac	[0.0034684106,-0.015824834,-0.009554	문서도 제한구역 표지 미	["기관": "공무원연금공단", "년도": 202
28	8da06c3a-f399-47f5-afb1-082ba7e7d	89b44584-d2ae-4ca0-a46a-d207b2ac	[0.0016005657,-0.029547844,0.010724	시스템(서버)실 화재() 방지대	["기관": "공무원연금공단", "년도": 202
29	4104754f-4a6a-4a6d-9b9a-9c9e5a871	89b44584-d2ae-4ca0-a46a-d207b2ac	[-0.015432744,-0.021668928,0.012222	다만기()에 대한 처리 비	["기관": "공무원연금공단", "년도": 202

4) RCM 선정 및 질의 생성

RCM 선정 및 질의 생성 과정은 리스크의 중요도를 반영하여 LLM이 실질적이고 실무 중심의 감사 착안사항을 도출할 수 있도록 하는 핵심 단계이다. 본 감사에서는 ‘2024년도 위험평가(업무기반, 방만경영) 결과¹⁸⁾’를 기반으로 [표 1]과 같이 정보화사업 산출물 관리, PC 접근 및 권한관리, 전산장비 폐기 등 리스크가 높은 분야를 우선적으로 선정하였다. 이들 항목은 정보보안, 자산관리, 사업관리 측면에서 반복적인 이슈 발생 가능성이 높은 영역으로, 감사 착안 시 우선순위가 높은 사안들이다. 선정된 RCM 항목을 바탕으로 구체적이고 타깃화된 질의문을 [표 2]와 같이 작성하였다.

[표 1] 2024년도 위험평가 중 IT분야 고위험 분야(중위험 이상)

분류	고유위험	평가점수	리스크등급
(생 략)			

18) 감사실-0000 (2024.00.00.) “2024년도 위험평가(업무기반, 방만경영) 결과 보고”

[표 2] RCM기반 LLM 질의문

선정된 RCM 항목	LLM 질의문
정보화사업산출물	DB 모델링 표준에 대한 감사착안사항을 알려줘
PC 접근 및 권한관리	CMOS 암호화에 대한 감사착안사항을 알려줘
전산장비폐기	시스템 활용에 대한 감사착안사항을 알려줘

5) LLM 질의를 통한 감사착안사항 도출

본 감사에서는 OpenAI¹⁹⁾의 API²⁰⁾를 이용하여 LLM모델(GPT-4o-mini²¹⁾)을 사용하였다. [그림 6]과 같이 LLM모델에 [표 2]에서 만든 RCM 기반 LLM 질의문을 입력하였고, 입력된 질의에 대해 벡터 데이터베이스에서 유사한 과거 처분요구서를 검색하여 이를 기반으로 LLM모델은 실제 감사 환경에서 적용 가능한 구체적인 감사착안사항을 제안하였다.

[그림 6] LLM기반 감사착안사항 질의

조회 - DB 모델링 표준에 대한 감사착안사항을 알려줘

```

# 시스템 초기화
rag_system = AuditRAGSystem()

# 질의 실행
question = "DB 모델링 표준에 대한 감사착안사항을 알려줘"
answer = rag_system.generate_answer(question)
print('')
print('답변 : ')
print(answer)

```

context : - 유역수도 운영지원시스템 DB 연계 현실화 및 대응방안 마련 (한국수자원공사, 2023)
- DB 모델링 표준 준수에 관한 사항 (기술보증기금, 2020)
- DB 접근제어 통제·관리 철저 (한국철도공사, 2023)

답변 :
감사 처분요구사항: DB 모델링 표준 준수에 관한 사항 (기술보증기금, 2020)

감사착안사항:
1. DB 모델링 설계 문서의 검토와 승인의 적정성을 평가하여 표준 준수를 확인할 것.
2. 표준 준수를 위한 교육 및 훈련 프로그램이 운영되고 있는지 점검할 것.
3. 실제 DB 구현이 설계된 모델링 표준을 따른 사례 분석을 통해 확인할 것.
4. 표준 미준수의 사례 발생 시 그 원인과 해결 방안에 대한 적시 보고 및 후속 조치 여부 점검할 것.
5. DB 모델링 표준의 주기적 업데이트 및 점검 절차가 존재하는지 확인할 것.

출처: 기술보증기금, 2020

19) OpenAI : 미국의 비영리 단체. 대형 언어 모델(LLM)과 이를 기반으로 하는 ChatGPT 등의 소프트웨어를 제공

20) OpenAI가 개발한 AI모델에 액세스하기 위해 공개된 API, 일정한 비용을 지불하면 AI모델을 사용할 수 있음

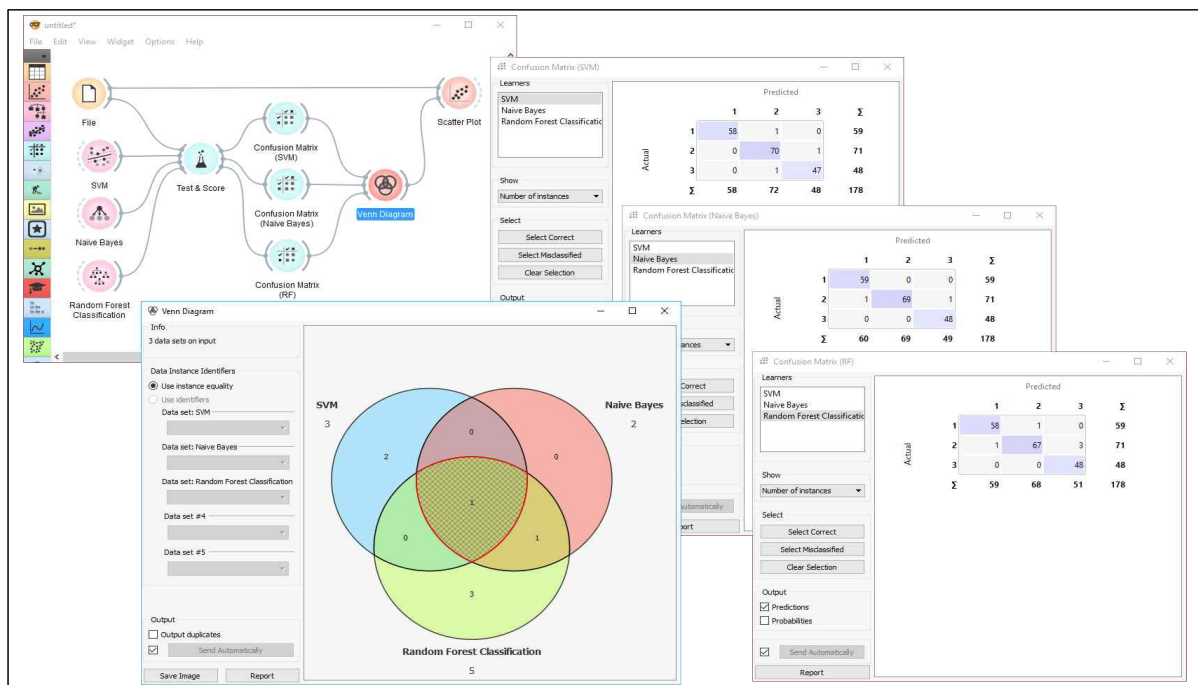
21) GPT-4o-mini : OpenAI에서 개발한 소형화된 차세대 다중 모달(multimodal) 언어 모델로, GPT-4o(Omni)의 경량화된 버전

다. 빅데이터 분석 도구(Orange3)를 사용한 데이터 시각화

1) 빅데이터 분석 도구(Orange3) 개요

Orange3는 빅데이터 분석 도구로써 사용자 친화적인 시각적 인터페이스를 제공하는 오픈소스 플랫폼으로, 프로그래밍 없이도 머신러닝²²⁾, 데이터 시각화²³⁾, 탐색적 데이터 분석²⁴⁾ 등을 수행할 수 있다. Orange3는 다양한 데이터 형식을 지원하며, [그림 7]과 같이 비전문가도 직관적으로 데이터 분석 워크플로우를 구성하고 조작할 수 있어, 실무 기반의 신속한 데이터 분석에 적합한 도구이다.

[그림 7] Orange 화면



2) 감사 데이터 수집

분석을 위한 데이터를 확보하는 과정으로 본 감사에서는 ☆본부의 신규 입사자 및 퇴직자의 인사정보와 ▼시스템의 권한 부여일과 권한 회수일을 각각 수집하였다.

22) 머신러닝(Machine Learning) : 인공지능(AI)의 한 분야로, 컴퓨터가 명시적인 프로그래밍 없이도 데이터를 기반으로 학습하고 개선할 수 있도록 하는 기술

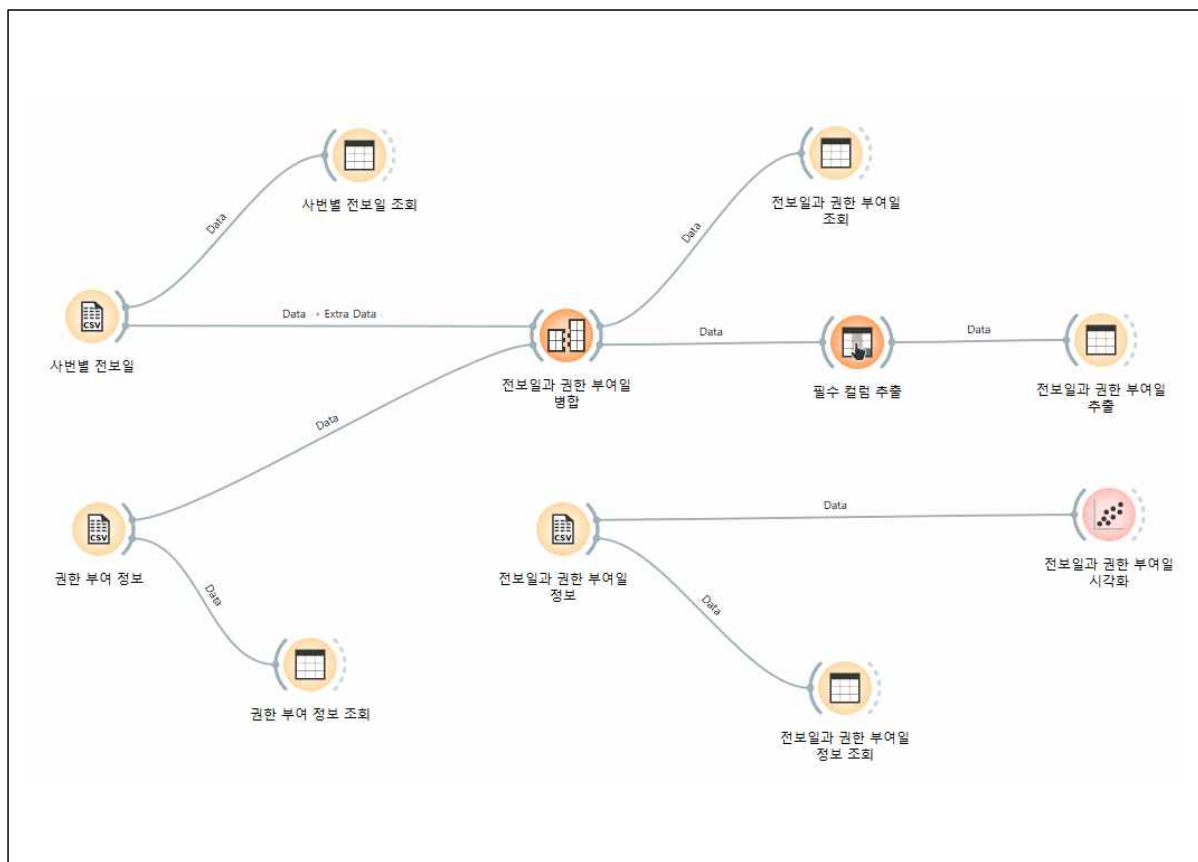
23) 데이터 시각화 : 복잡한 데이터를 그래프, 차트, 맵, 대시보드 등의 시각적 형식으로 표현하여, 사람에게 더 쉽게 이해하고 해석할 수 있도록 도와주는 기술

24) 탐색적 데이터 분석(Exploratory Data Analysis, EDA) : 데이터의 기본 구조, 패턴, 이상치, 관계 등을 시각적 도구와 통계적 기법을 활용해 탐색하는 과정

3) 빅데이터 분석을 위한 워크플로우 개발

(신규 입사자의 권한 부여일 비교 분석 워크플로우) 신규 입사자의 권한 부여 지연 여부를 분석하기 위해, [그림 8]과 같이 워크플로우를 구성하였다. 신규 입사자의 전보일과 ▼시스템에서의 권한 부여일을 각각 CSV형식의 데이터로 불러왔으며, 두 데이터셋을 사번을 기준으로 병합하였다. 권한 부여일이 없는 데이터를 제거하고, 날짜 형식을 통일하였다. 이후, 전보일과 권한 부여일 사이의 일수 차이를 계산하고, 차이가 10일 이상인 사례를 식별하여 권한 부여 지연 가능성을 도출하였다.

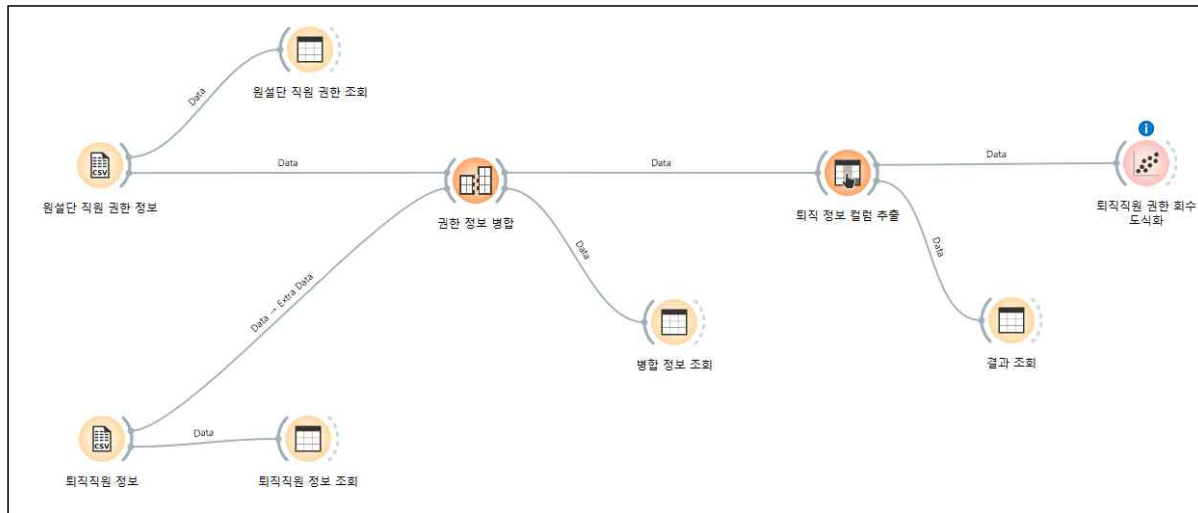
[그림 8] 신규입사자와 권한부여일 비교 워크플로우 화면



(퇴직자의 권한 회수일 비교 분석 워크플로우) 퇴직 직원의 권한 회수 지연은 정보보안 측면에서 중대한 리스크를 초래할 수 있으므로, [그림 9]와 같이 퇴직일과 실제 권한 회수일 간의 차이를 분석하는 워크플로우를 구성하였다. 퇴직자의 퇴직일과 ▼시스템에서의 권한 회수일을 각각 CSV형식의 데이터로 불러왔으며, 두 데이터셋을 사번을 기준으로 병합하였다. 권한

부여 일이 없는 데이터를 제거하고, 날짜 형식을 통일하였다. 이후, 퇴직일이후에도 권한이 유지된 사례, 즉 권한 회수일이 퇴직일보다 늦은 경우를 식별하여 정보보안 관리 미흡 가능성을 도출하였다.

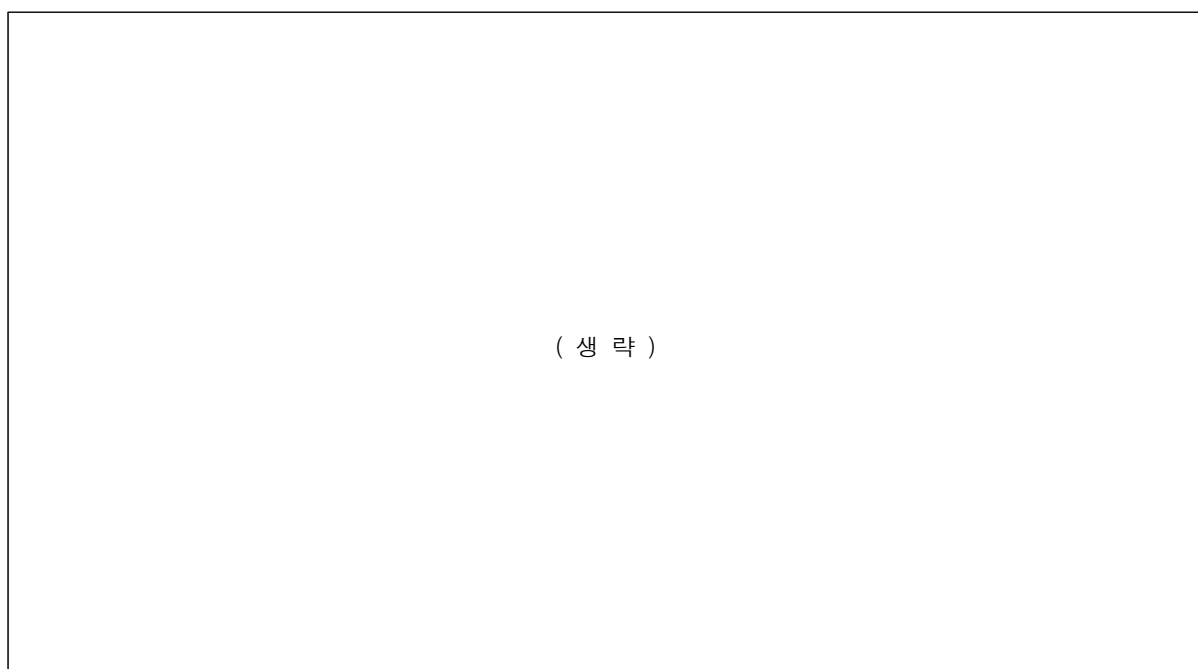
[그림 9] 퇴직직원과 권한회수일 비교 워크플로우 화면



4) 감사 데이터 시각화 및 분석

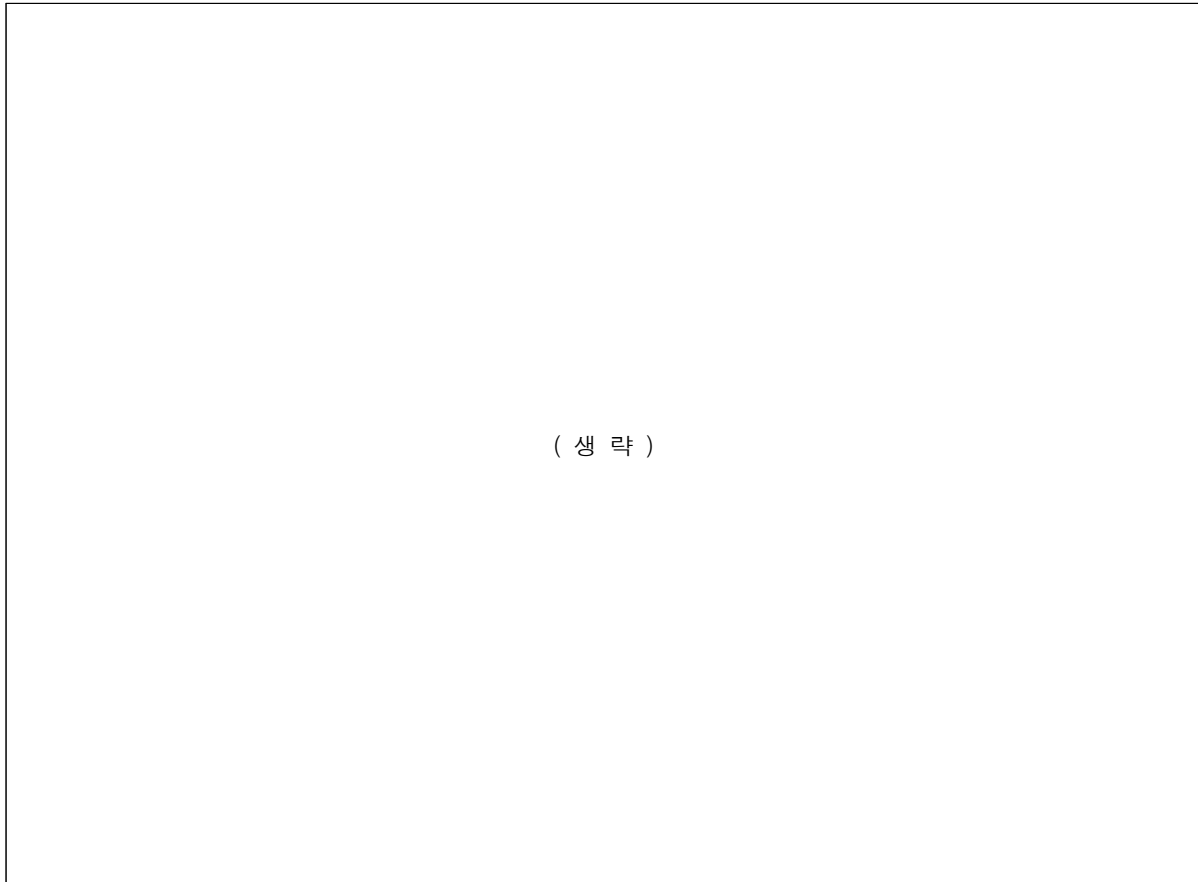
(신규 입사자의 권한 부여일 비교 시각화 및 분석) [그림 10]과 같이 권한 부여 지연 일수를 산점도로 시각화한 결과, 평균 00일, 최대 00일의 지연이 발생한 사실을 확인하였다.

[그림 10] 전보일과 권한부여일 시각화



(퇴직자의 권한 회수일 비교 시각화 및 분석) [그림 11]과 같이 산점도로 권한 회수 지연일 차이를 시각화하여 권한 회수가 00일 이상 지연된 사례가 총 00건, 최대 0000일이 지연된 사례도 존재함을 확인하였다.

[그림 11] 퇴직일과 권한회수일 시각화



(다 음 장 에 계 속)

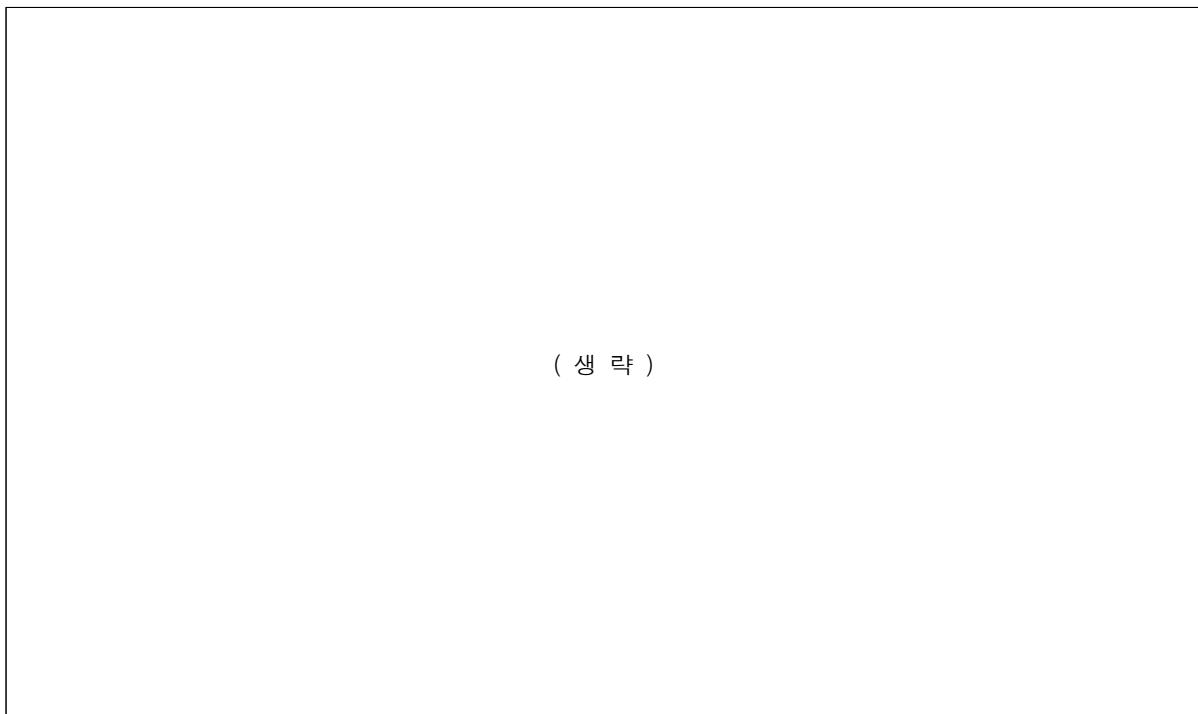
II. 감사 대상 현황

1. 감사 대상 조직 및 인력

이번 감사의 피감부서인 IT 관련 부서는 <본부의 ♣실 및 ☆본부의 ♠실, ◀연구원의 ●연구소와 연구소 산하 ♥실로, 총 0연구소 0실 0팀에 000명의 내부직원과 시스템 유지보수를 위한 외주인력 00명으로 운영되고 있다.

♣실은 회사 정보보호·보안, 정보화사업 총괄 기능을 담당하며, ♥실은 디지털 설계 관련 데이터 구축 및 활용, 설계·건설정보 및 도면 등 사업 기술지원 분야 시스템 지원 총괄 부서이다. 또한, ♠실은 설계기술 및 인허가-설계 요건 일치성 점검 등 =시스템 종합 관리 총괄 업무를 담당한다. 회사 IT 부서 조직도 및 상세 인력 현황은 아래 [그림 12] 및 [표 3]와 같다.

[그림 12] IT 부서 조직도



[표 3] IT부서 인력현황

부서	팀	인원(명)	비고
(생 략)			
합 계		000	별도 외주인력 00명

* ♠실 ▣팀의 IT 담당자는 0명(0000.0.0. 기준)

2. 회사 정보시스템 현황

해당 부서의 전체 담당 정보시스템 목록은 아래 [표 4~7]과 같으며, 예비 감사(2025.7.2. ~ 7.15.) 과정을 통해 본 감사의 응용통제 분야 감사 대상으로 ♣실, ♠실, ♥실의 전체 정보시스템 중 총 8개의 시스템을 선정하였다.

♣실에서 관리하는 총 00여개의 정보시스템 중 ♠시스템, ○시스템(○), ▣을 IT응용통제 대상 시스템으로 선정하였다. 2024년도 기관 종합청렴도평가 결과 부패인식 부분에서 낮은 점수를 받은 항목 중 하나인 ‘인사위반(00.0점, 공기업 유형대비 -0.0점)’ 분야를 고려하여 ♠시스템을 선정하였으며, 국내 신규 원전사업 수주와 SMR²⁵⁾ 관련 신규사업 진행 그리고 체코 원전 수주²⁶⁾에 따른 다양한 사업들의 사업관리 중요성 증대에 따라 ○시스템을 선정하였으며, 회사의 모든 시스템이 연결되어 허브 역할을 하는 ▣ 시스템을 선정하였다.

25) SMR(Small Modular Reactor, 소형 모듈러 원자로) : 기존 대형 원자로보다 작고, 표준화된 모듈 방식으로 제작되어 현장에서 조립하는 차세대 원자력 발전소

26) 2024.7월 우선협상대상자로 선정, 2025.6.4. 최종 계약

[표 4] ♣실 담당 정보시스템

순번	정보시스템명	현업 담당부서	도입년도	망구분	비고
(생 략)					

순번	정보시스템명	현업 담당부서	도입년도	망구분	비고

♠실에서 관리하는 총 0개의 시스템 중 ☆본부에서 설계된 모든 설계문서를 관리하는 시스템을 점검하기 위해 ▷포탈, ◇시스템, NEW ◇시스템을 IT응용통제 대상 시스템으로 선정하였다.

[표 5] ♠실 담당 정보시스템

순번	정보시스템명	현업 담당부서	도입년도	망구분	비고
(생 략)					

●연구소는 인공지능 연구 업무 및 시스템 최적화 연구업무를 수행하고 있으며, 관련 시스템으로 AI분석 플랫폼과 ∞(사내 GPT-4o급 생성형 AI 서비스) 시스템을 구축·운영하고 있다.

[표 6] ●연구소 담당 정보시스템

순번	정보시스템명	현업 담당부서	도입년도	망구분	비고
(생 략)					

♥실에서 관리하는 총 00개의 시스템 중 ◆시스템(이하 ‘□’)와 ■(이하 ‘■’)시스템을 IT응용통제 대상 시스템으로 선정하였다. \$본부에서 설계되는 설계문서를 관리하는 □와 P&ID 도면에서 기자재 정보(Equipment, Damper, Valve, Instrument, Line 등)을 추출하여 데이터베이스 化 하는 ■ 시스템을 선정하였다.

[표 7] ♥실 담당 정보시스템

순번	정보시스템명	현업 담당부서	도입년도	망구분	비고
(생 략)					

순번	정보시스템명	현업 담당부서	도입년도	망구분	비고

(다 음 장 에 계 속)

Ⅲ. 감사 결과

1. 감사 결과 총평

- 본 감사는 2025년도 감사업무 추진계획에 따라 실시된 특정감사로, IT일반통제 및 IT응용통제 측면에서 총 19건의 지적사항이 확인되었다.
- 감사 착안사항의 체계적 도출을 위해 RAG 기반 LLM 시스템을 구축하여, 정보화사업산출물, PC 접근 및 권한관리, 전산장비폐기 등 2024년도 위험평가에서 고위험으로 분류된 분야를 선정하였다.
- 감사 과정에서 Orange3 빅데이터 분석 툴을 활용하여 감사자료를 시각화하여, 신입 직원의 권한부여 시점 지연 및 퇴직 직원의 권한 회수 지연 여부를 분석하였다.
- IT응용통제 분야에서는 ♡시스템의 본부 차원 권한관리 부적정, ◇시스템의 신입 및 퇴직자 권한관리 미흡, 보안등급 관리 부적정 등의 문제가 지적되어 시스템 접근 권한 관리의 미흡과 정보보안 측면에서 취약점이 드러났다.
- 특히, ☆본부 ▼시스템(◇)에서는 영업비밀 자료의 등급 관리가 규정에 부합하지 않게 운영되고 있으며, 클라이언트 측에서 권한을 임의로 조작할 수 있는 구조적 결함으로 인해 2급(특별보호자료)에 해당하는 영업비밀 문서가 무단으로 출력되는 보안 취약점이 발견되었다. 이는 정보 유출로 이어질 가능성을 내포하고 있어 시급한 기술적·관리적 보완 조치가 필요하다.
- 본 감사에서는 정보시스템의 권한관리, 보안등급 관리 등 보안측면의 미흡한 점을 지적하며, 정보시스템 전반에 대한 개선을 요구하였다.

2. 지적사항 총괄

- ☐ 본 감사결과 아래의 [표 8]과 같이 총 19건의 사항을 지적하고, 감사대상부서에 처분요구하였다.

[표 8] 감사 결과 지적사항 현황

(단위: 건, 명)

합계		징계 (인원)	경고·주의 (인원)	현지조치	권고	통보	시정	개선요구
건수	인원							
19	2	-	1(2)	1	4	8	3	2

3. 주요 문제점

- ☐ 감사결과 확인한 주요 문제점은 다음과 같다.

① 정보화사업 과업 내용과 범위 설정 부적정【통보】【권고】

- ♥실은 □ 고도화 사업의 제안요청서를 작성하면서, 「소프트웨어진흥법」 제44조에 따라 과업의 내용과 범위를 명확하게 기재해야 했으나, 제안요청서 내 데이터베이스 관련 요구사항을 과다하게 작성함
- ♣실이 운영하는 과업심의회는 과업의 적정성을 종합적으로 점검할 책임이 있으나, 실제 심의 과정에서는 과업 내용의 적정성에 대한 충분한 검토 없이 ‘적정’으로 의결한 사례가 확인됨

② 미사용 정보시스템 및 메뉴에 대한 운영관리 미흡【개선요구】【통보(2)】

- ►시스템의 경우 0000.0월부터 0000.0월까지의 기간 동안 활용 실적이 0건에 불과하였으나, 이에 대한 사용 활성화, 기능 정비 또는 폐기 여부 검토가 이루어지지 않았음.
- ▣의 △, 협업·소통 > ▲, ▼시스템의 +, ▽ 게시판 등은 장기간 비활성 상태임에도 불구하고 해당 메뉴에 대한 정비, 통폐합 또는 폐기 검토는 실시되지 않아, 정보 자원의 비효율적 운영으로 이어지고 있음.

③ 전사적 관점의 정보화기본계획 수립 미흡 【권고(3)】 【통보(2)】

- 0000년에 수립된 정보화기본계획(0000 ~ 0000년)을 분석한 결과, 대부분의 추진 과제가 䄠실과 䄡실의 업무 중심으로 구성되어 있어 ♠실 등 타 IT 관련 부서의 정보화 추진계획 및 과제가 충분히 반영되지 않은 것으로 확인되어 전사적 정보화 전략의 포괄성과 균형성에 한계가 있음

④ ♡시스템 본부권한 담당자의 조회 및 관리 권한 부적정 【시정】 【통보】

- 「행정기관 정보시스템 접근권한 관리 규정」 제13조에 따르면, 접근권한의 범위는 업무 필요범위 내에서 차등화하여 불필요한 정보 접근을 제한해야 하나, ♡시스템 내에서 본부권한 담당자가 임의로 사번을 변경하는 방식으로 타 본부 소속 평가 대상자의 정보를 조회할 수 있는 보안 취약점이 존재하는 것으로 확인

⑤ ◆ 시스템 신입 및 퇴직자 권한관리 부적정 【통보(2)】 【개선요구】

- 신규 입사자 또는 전입 직원에 대한 ▼시스템(◆) 접근권한 부여가 신속하게 이루어지지 않아 업무 시작 초기에 시스템을 활용할 수 없는 문제가 있음
- 퇴직 직원의 시스템 접근 권한을 수기 접수로 회수하여, 퇴직자가 신청서를 제출하지 않거나 지연할 경우, 퇴직 사실을 인사 발령 공문 등을 통해 나중에야 확인하게 되어 권한 회수가 지연되는 문제가 확인됨

⑥ ◆ 시스템 보안등급 관리 부적정 【주의】 【시정(2)】

- 「영업비밀보호관리규정」 및 기술업무절차서 「사업문서 등급 및 이용관리」 (TAP-00-00)의 분류 기준과 부합하지 않게 운영되고 있어, 진행중인 사업의 설계 도면은 2급(특별보호자료) 자료이나 출력 시에는 4급 자료로 표기되는 불일치 문제가 있음
- 사용자의 역할 및 권한을 결정하는 정보가 서버가 아닌 클라이언트 측에서 관리되고 있어, 출력 및 저장할 수 없는 종료사업의 설계문서 2급(특별보호자료) 자료를 파라미터 변조로 3급(일반보호자료) 자료로 변경하여 출력 및 저장할 수 있는 문제가 있음

⑦ 인터넷 미니 PC CMOS 패스워드 미설정 사용자에게 대한 보안조치 및 전사 안내 필요 【현지조치】

- 「사용자보안 관리지침」 제34조에 따르면, 외부망용 미니 PC는 부팅 시 반드시 CMOS 패스워드를 설정해서 사용해야 하나, 일부 인터넷 미니 PC 사용자가 회사 보안 지침을 준수하지 않고 CMOS 패스워드를 미설정한 채 장비를 사용하고 있는 사례가 확인되어 현지조치함

IV. 처분요구사항 일람표

번호	조치부서 (대상자)	건명	처분요구			조치 기한	감사자
			처분 종류	재정 조치	신분 조치		
1	♥실 (♥실장)	정 보 화 사 업 과 업 내 용 과 범 위 설 정 부 적 정	통 보	-	-	2개월	A 검 사 역 등 7명
2	♣실 (♣실장)	정 보 화 사 업 과 업 내 용 과 범 위 설 정 부 적 정	권 고	-	-	2개월	
3	♣실 (♣실장)	미 사 용 정 보 시 스 템 및 메 뉴 에 대 한 운 영 관 리 미 흡	개 선 요 구	-	-	2개월	
4	♣실 (♣실장)	미 사 용 정 보 시 스 템 및 메 뉴 에 대 한 운 영 관 리 미 흡	통 보	-	-	2개월	
5	♣실 (♣실장)	미 사 용 정 보 시 스 템 및 메 뉴 에 대 한 운 영 관 리 미 흡	통 보	-	-	2개월	
	♠실 (♠실장)						
6	♣실 (♣실장)	전 사 적 관 점 의 정 보 화 기 본 계 획 수 립 미 흡	권 고	-	-	2개월	
7	♣실 (♣실장)	전 사 적 관 점 의 정 보 화 기 본 계 획 수 립 미 흡	통 보	-	-	2개월	
8	♣실 (♣실장)	전 사 적 관 점 의 정 보 화 기 본 계 획 수 립 미 흡	통 보	-	-	2개월	
9	♥실 (♥실장)	전 사 적 관 점 의 정 보 화 기 본 계 획 수 립 미 흡	권 고	-	-	2개월	
	●연구소 (●연구소장)						
10	♠실 (♠실장)	전 사 적 관 점 의 정 보 화 기 본 계 획 수 립 미 흡	권 고	-	-	2개월	
11	♣실 (♣실장)	♣ 시스템 본부권한 담당자의 조회 및 관리 권한 부적정	시 정	-	-	2개월	
12	♣실 (♣실장)	♣ 시스템 본부권한 담당자의 조회 및 관리 권한 부적정	통 보	-	-	2개월	
13	♠실 (♠실장)	◆ 시스템 신입 및 퇴직자 권한관리 부적정	통 보	-	-	2개월	
14	♠실 (♠실장)	◆ 시스템 신입 및 퇴직자 권한관리 부적정	개 선 요 구	-	-	2개월	
15	◇처 (◇처장)	◆ 시스템 신입 및 퇴직자 권한관리 부적정	통 보	-	-	2개월	
	♣실 (♣실장)						
16	감사실 (H 등 2명)	◆ 시스템 보안등급 관리 부적정	주 의	-	2	-	
17	♠실 (♠실장)	◆ 시스템 보안등급 관리 부적정	시 정	-	-	2개월	
18	♠실 (♠실장)	◆ 시스템 보안등급 관리 부적정	시 정	-	-	2개월	
19	♣실 (♣실장)	인 터 네 트 미 니 PC CMOS 패 스 워 드 미 설 정 사 용 자 에 대 한 보 안 조 치 및 전 사 안 내 필 요	현 지 조 치	-	-	-	

V. 감사결과 처분요구서 [별첨1 참조]

- 별첨
1. 감사결과 처분요구서 각 1부.
 2. 현지조치사항 내역서 1부.
 3. 감사증거자료 각 1부.
 4. 감사계획 대비 결과 대조표 1부.
 5. 감사 관련 주요 문서 각 1부.
 6. 벤치마킹 관련 문서 각 1부.
 7. 교차감사 의견서 1부.
 8. 적극행정 면책신청서 1부.
 9. 감사 관련 감사인 교육 이수 실적 각 1부.

일련번호	2025-39
------	---------

상 임 감 사 통 보, 권 고

제 목 : 정보화사업 과업 내용과 범위 설정 부적정

조 치 부 서 : ♥실, ♣실

내 용

1. 업무 개요

♥실(구. ㅁ실 ㉠팀¹⁾)은 0000. 0월, ◆ 시스템 고도화 사업(이하 ‘□²⁾ 고도화 사업’)의 과업 범위를 설정하여 0000. 0. 00. □ 고도화 사업을 발주하였으며, 0000. 0. 0.부터 0000. 0. 0.까지 해당 사업을 수행하였다.

♣실(구. ㅁ실 ㉡팀³⁾)은 0000. 0월부터 현재까지 「소프트웨어 진흥법」 제50조 (소프트웨어사업 과업심의위원회) 및 「소프트웨어사업 과업심의회 운영지침」에 따라 소프트웨어 과업 내용 확정, 과업 변경 승인, 계약금액 및 계약기간 조정 등의 사항을 심의하는 과업심의회를 운영하였다.

2. 관계법령 및 판단기준

「공공기관의 데이터베이스 표준화 지침」 제8조 (공공데이터베이스 표준 수립 및 적용)에 따르면 공공데이터베이스 표준을 수립하고 적용해야 한다.

「소프트웨어 진흥법」 제44조 (소프트웨어사업의 과업 범위) 제1항에

1) 0000. 0. 0. 「직제규정시행세칙」이 개정됨에 따라 ㅁ실의 ㉠팀이 ♥실로 이관됨

2) □ : 설계 문서의 등록, 변경, 검토, 승인, 발행, 제출 등 라이프사이클 관리 및 제반 기능을 제공하는 ◆시스템

3) 0000. 0. 0. 「직제규정시행세칙」이 개정됨에 따라 ㅁ실의 ㉡팀이 ♣실의 ㉢팀으로 통합됨

따르면 소프트웨어사업을 기획하고 예산을 편성하는 경우 과업의 내용과 범위를 명확하게 하여야 하고, 동 조 제2항에 따르면 소프트웨어사업을 발주하는 경우 소프트웨어사업자가 과업 규모를 산정할 수 있도록 요구사항을 상세하게 작성·공개하게 되어있다. 「요구사항 상세화 실무 가이드4)」에서 데이터 요구사항은 데이터 구축을 위해 데이터 수집 및 입력 방법, 초기 데이터 구축, 데이터 이관, 데이터 관리, 데이터 품질 등의 요건을 작성하게 되어있다.

또한, 「소프트웨어진흥법」 제50조(소프트웨어사업 과업심의위원회) 및 「공공소프트웨어사업 과업심의 가이드5)」에 따르면, 소프트웨어 과업심의위원회는 제안요청서를 기반으로 과업내용의 적정성을 비교·종합적으로 검토하게 되어있다. 과업심의위원회(이하 ‘과업심의회’6))는 국가기관 등이 발주하는 모든 SW사업을 대상으로 하며, ♣실은 위원장 0명을 포함한 0명(외부 0명, 내부 0명)의 위원으로 운영하고 있다.

따라서 ♥실은 □ 고도화 사업에서 데이터베이스변경 시 데이터베이스 표준을 수립하고 적용해야 한다. 그리고 제안요청서의 작성은 「소프트웨어진흥법」 제44조 (소프트웨어사업의 과업 범위)에 따라 과업 내용과 범위를 명확하게 작성해야 하며, 「요구사항 상세화 실무 가이드7)」의 데이터 요구사항 작성 가이드에 따라 제안요청서의 데이터베이스 요구사항을 명확하게 작성해야 한다.

4) 2021 공공 SW사업 제안요청서 작성을 위한 요구사항 상세화 실무가이드(과학기술통신부, 정보통신산업진흥원(NIPA))
5) 공공소프트웨어사업 과업심의 가이드(과학기술정보통신부/정보통신산업진흥원, 2022.12.) 소프트웨어 과업 내용의 확정과 적정 사업 기간의 산정 등 업무에 대한 가이드
6) 회사 사규 「소프트웨어사업 과업심의회 운영지침」에 과업심의위원회를 과업심의회라는 명칭을 사용하고 있음
7) 요구사항 상세화 실무 가이드(과학기술정보통신부/정보통신산업진흥원, 2022.12.) : 공공 소프트웨어사업 기획 시 불명확한 요구사항으로 사업부실과 품질저하, 수주기업 수익성 악화 등의 문제가 지속적으로 제기되는 현실을 고려하여, 사업추진 준비 단계부터 요구사항 명확화 수준의 획기적인 제고를 위해 요구사항 상세화 실무 가이드를 안내

♣실은 과업심의회가 「소프트웨어 진흥법」 제44조 (소프트웨어사업의 과업 범위) 제1항에 따라 제안요청서의 과업이 내용과 범위가 명확하게 되었는지 검토될 수 있도록 운영해야 한다.

3. 감사결과 확인된 문제점

감사 대상 기간(2022.7.1. ~ 2025.6.30.) 동안 발주된 시스템을 대상으로 데이터베이스 모델링 표준 준수 여부를 확인한 결과 [표 1]과 같이 각 정보 시스템별 준수 상태를 확인하였다.

[표 1] 데이터베이스 모델링 표준 준수여부

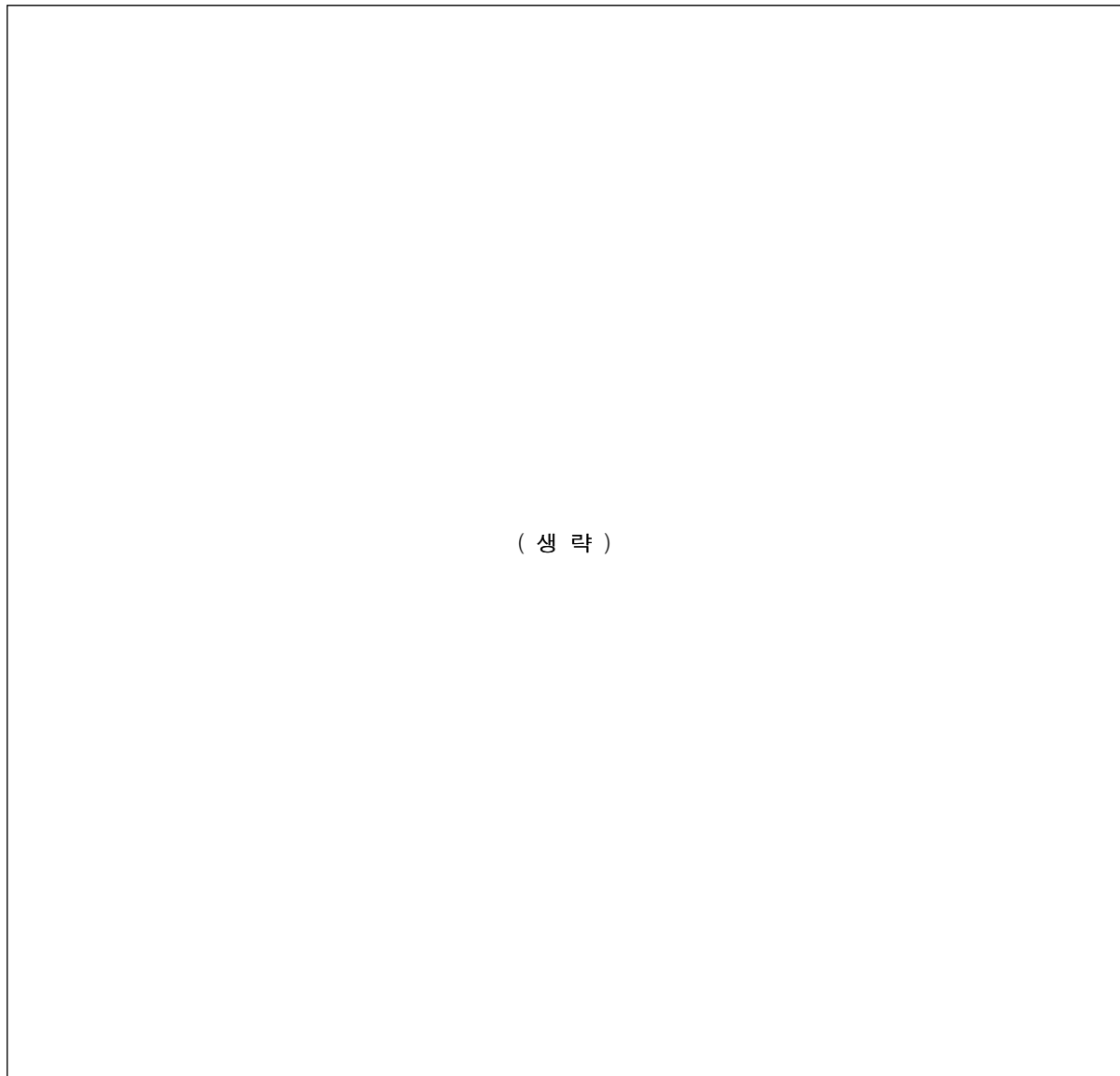
부서	정보시스템	준수여부	비고
(생 략)			

그 결과, ♥실이 추진한 □ 고도화 사업의 경우, 총 컬럼 0000건 중 데이터 타입 불일치가 000건, 한글 컬럼명 불일치가 000건으로 오류율이 00%에 달하는 것으로 나타났다. 이에 대해 ♥실은 □ 고도화 사업에서 제안요청서에 데이터베이스 과업은 있었으나 인터페이스 변경이 주 목적인 사업으로 표준화가 불가능하여 수행하지 않았다고 답변⁸⁾하여 해당 정보화사업의 과업 내용과 범위가 적정했는지 추가 검토를 시행하였다.

8) 0000년 0월 00일 ♥실 답변서 “본 발주에서 사용한 데이터 표준화 요구사항은 데이터 표준화가 필요한 경우를 위한 비 기능 요구사항으로 당시 여러 정보화 사업에서 정형화하여 사용한 요구사항입니다. 그러나 본 사업의 경우 인터페이스 변경이 주 목적인 사업으로 Table, 컬럼 및 데이터 변경 시 ☞의 타 사업 및 시스템과 연계 문제가 발생함에 따라 표준화가 불가능하여 수행하지 않았습니다.”

♥실은 0000.0월 □ 고도화 사업을 추진하면서, [그림 1]과 같이 회사 표준양식과 「공공데이터베이스 표준화 관리 매뉴얼⁹⁾」에 따라 데이터 요구사항(DAR, Data Requirement)을 작성하였는데, 해당 사업은 데이터베이스 변경 없이 웹 표준 기반의 사용자 인터페이스(UI) 재구축을 주목적으로 하는 개선 사업임에도 불구하고, 사업의 특수성을 고려하지 않고 기존의 회사 표준 제안요청서 양식을 수정 없이 그대로 사용한 것을 확인하였다.

[그림 1] □ 고도화 사업 데이터요구사항



(생 략)

9) 공공데이터베이스 표준화 관리 매뉴얼(행정안전부/한국지능정보사회진흥원, 2023.4.) : 공공기관에서 구축한 신규 및 고도화 시스템의 DB가 공공데이터 표준화 대상임

그 결과, [표 2]과 같이 해당 사업은 데이터베이스(DB) 구축이 없어, DB 설계 또는 데이터 마이그레이션¹⁰⁾ 역무가 불필요한 사업임에도 불구하고, 제안요청서의 데이터 요구사항에는 DB설계 및 표준화와 관련된 요구사항을 과도하게 작성한 것으로 확인되었다. 요구사항 DAR-004 및 DAR-005의 경우, 기존 DB를 변경 없이 사용하는 구조상 DB 설계 변경이나 데이터 마이그레이션 수행이 불가능하였으며, 실제로도 요구사항 중 일부 과업은 이행되지 않았다.

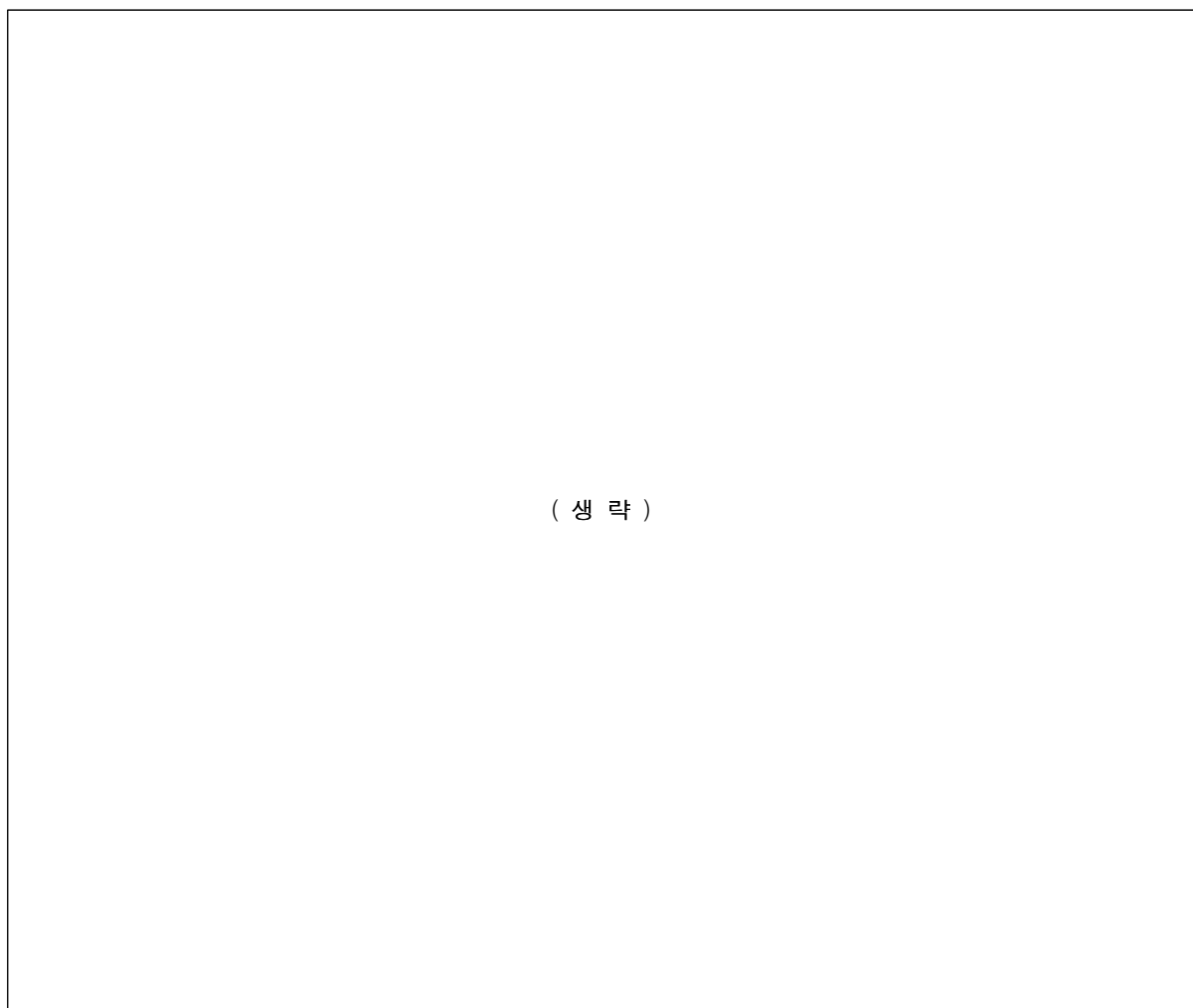
[표 2] □ 고도화 사업 데이터 요구사항 수행 여부

요구사항		세부내용 요약	수행 여부	비고
번호	명칭			
(생 략)				

10) 구 시스템의 데이터베이스의 데이터를 신규 시스템의 데이터베이스로 이관하는 작업

또한, ♣실에서 운영하는 과업심의회는 [그림 2]와 같이 제2차 과업심의회¹¹⁾를 통해 □ 고도화 사업을 심의하였으나, □ 고도화 사업은 기존 DB를 변경 없이 사용함에 따라 DB 설계나 데이터 마이그레이션 역무가 존재하지 않는 사업임에도 불구하고 이에 대한 별도의 검토나 지적 없이 “과업내용은 적정함”이라는 포괄적인 판단으로 부실하게 심의하였다.

[그림 2] 제0차 과업심의회(□ 고도화 사업) 결과



그 결과, 제안요청서에 명확하지 않은 과업이 내용과 범위가 그대로 반영된 채 발주되어, 입찰 참가자에게 불완전한 정보가 제공되는 결과를 초래하였다.

11) ●팀-00 (0000.0.00.) “제0차 소프트웨어사업 과업심의회 심의결과 통지”

관계부서 의견 및 검토결과 ♥실은 □ 고도화 사업 제안요청서에 작성된 데이터베이스 관련 요구사항은 회사 표준양식과 「공공데이터베이스 표준화 관리 매뉴얼」의 금액별 진단기준에 따라 과업을 포함하였고¹²⁾, 필요는 없는 역무이나 사업 수행 중에 필요할 수도 있어 데이터베이스 설계나 표준화 관련 역무를 추가하였다고 답하였다.

그러나, 소프트웨어진흥법 제44조 (소프트웨어사업의 과업 범위) 제1항에 따르면 과업의 내용과 범위를 명확하게 하여야 하며, 동 법 제2항에 따르면 요구사항을 상세하게 작성·공개해야 하게 되어있어, 이에 대한 항변은 받아들일 수 없다.

♣실은 과업심의회 운영과 관련하여, “과업심의회 운영부서가 안전의 특정 부분을 언급하거나 가이드라인을 제시할 경우, 이는 위원들의 공정한 평가를 저해할 수 있는 요인으로 작용할 수 있다.”고 답변하였다.¹³⁾

그러나, 제0차 과업심의회에서 심의된 □ 고도화 사업은 데이터베이스 관련 일부 역무가 원천적으로 불필요한 사업임에도 불구하고, 제안요청서에는 불필요한 요구사항이 과도하게 반영되었음에도, “과업내용은 적정함”으로 심의되었다.

또한 제00차 과업심의회에서 심사한 “☞ 관리 프로그램 기능 및 성능 개선 용역 발주 승인” 건의 경우, [그림 3]과 같이 용역비 산출내역서(FP) 와

12) 0000. 0. 00. ♣실 답변서에 해당사업 발주부서 의견 “데이터베이스 비용산정과 관련하여 정보시스템 구축비용은 “SW사업 대가산정 가이드”에 따라 기능 요구사항을 도출하고 이를 바탕으로 비용을 산정하고 있습니다. 따라서, 데이터베이스 관련 요구사항은 비기능 요구사항으로 데이터를 다루는 사업이 아닌 정보시스템 구축 사업의 경우 비용산정 시 포함하고 있지 않습니다. 제안요청서에 작성된 데이터베이스 관련된 요구사항은 행정안전부에서 “공공데이터베이스 표준화 관리 매뉴얼”을 배부하여 공공데이터 품질을 위해 제안요청서에 정형화된 데이터 관련 요구사항을 기재하도록 권고하고 있음을 참고하여 주시기 바랍니다.”

13) 0000. 0. 00. ♣실 답변서 “과업심의 안전에 대한 위원별 심의결과 내용은 각 위원들의 자율적인 견해로 인정이 되어야 하는 부분이므로 심의한 내용의 부족함에 대한 지적은 운영부서로서 임의 판단하여 심의 결과를 추가하거나 수정할 수 없을 것으로 판단됩니다. 또한, 과업심의회 운영부서 입장에서 안전에 대한 특정 부분을 언급하거나 가이드라인을 제시하는 경우, 공정한 평가를 저해할 수 있는 요인으로 적용될 우려가 있습니다.”

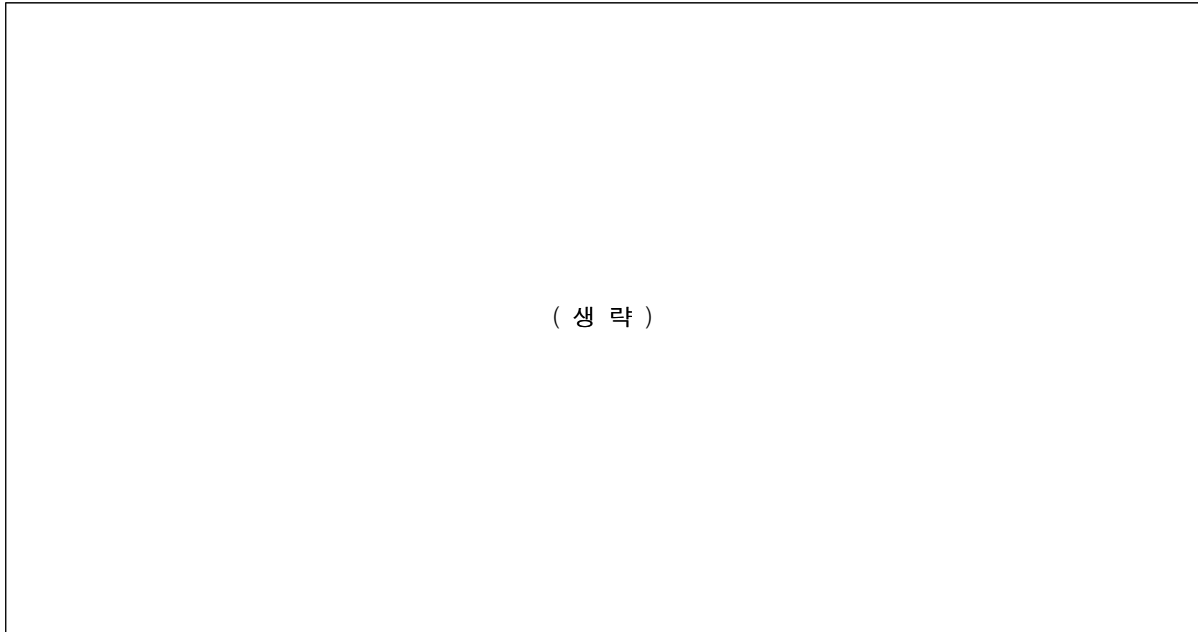
제안요청서상의 과업 내용 간 불일치가 존재하였으며, 이와 관련한 사항은 일상감사¹⁴⁾에서 이미 지적된 바 있다. 그럼에도 불구하고, 과업심의회는 [그림 4]와 같이 해당 불일치를 지적하지 않은 채 적정하다고 의결함으로써, 과업 내용의 적정성에 대한 실질적인 심의가 미흡하였음이 확인된다. 이러한 점을 종합적으로 고려할 때, ♣실의 주장은 과업심의회위원회의 실질적인 검토 기능 보완을 위한 운영부서의 역할을 충분히 반영하지 못하고 있어 개선이 필요하다.

[그림 3] 제00차 과업심의회에 제출한 기능점수 및 기능요구사항 불일치 사항

기능점수 산정
(생 략)
요구사항정의서 기능요구사항
(생 략)

14) 일상감사검토서-000(0000. 00. 0.) “☞ 관리 프로그램 기능 및 성능개선 용역 발주 승인”에서 용역비 산출내역서 (FP)와 제안요청서의 과업의 불일치 지적

[그림 4] 제00차 과업심의회 심의결과



조치할 사항

① ♥실장은 향후 소프트웨어사업 발주 시, 「소프트웨어 진흥법」 제44조 (소프트웨어사업의 과업 범위)에 따라 과업 내용과 범위를 명확하게 작성하시기 바랍니다. 【통보】

② ♣실장은 과업심의회 운영 시 과업의 적정성을 종합적으로 점검할 수 있는 항목을 마련하고, 이를 체계적으로 운영하여 심의의 실효성과 전문성을 제고하시기 바랍니다. 【권고】

일련번호	2025-40
------	---------

상 임 감 사

개선요구, 통 보(2)

제 목 : 미사용 정보시스템 및 메뉴에 대한 운영관리 미흡

조 치 부 서 : ♣실, ♠실

내 용

1. 업무 개요

♣실은 「직제규정시행세칙」에 따라 경영/행정 분야 정보시스템의 구축 및 유지관리 업무를 수행하고 있으며, ♠실은 ☆본부 설계전산화 및 시스템 운영 업무를 수행하고 있다. 또한, ♣실과 ♠실은 「정보화업무절차¹⁾」 제3조(분장업무)에 따른 각 분야의 정보화 주관부서로 동조 제1항7호에 따라 정보시스템의 운영 현황을 파악하고 및 정보화 운영성과를 측정하고 있다.

2. 관계법령 및 판단기준

회사의 「정보화업무절차」 제24조(정보시스템 운영성과 측정)에 따르면 정보시스템이 구축이 완료되어 서비스 운영이 개시된 날로부터 1년이 경과한 정보시스템을 대상으로 운영성과를 측정해야 하며, 측정 결과에 따라 정보시스템의 ‘유지’, ‘기능고도화’, ‘전면재개발’, ‘통폐합’, ‘폐기’ 등의 개선방안을 마련하여 조치하고 그 세부사항은 「전자정부 성과관리 지침」에서 정한 바에 따라야 한다.

1) 「정보화업무절차」는 0000.0.00. 「전산화업무절차」에서 명칭이 개정되었음

따라서 ♣실, ♠실은 정보시스템 서비스 운영일로부터 1년이 지난 정보시스템을 대상으로 운영성과를 측정하여, 활용도가 낮은 정보시스템을 ‘유지’, ‘기능고도화’, ‘전면재개발’, ‘통폐합’, ‘폐기’ 등의 개선 방안을 수립하고 이행하여야 한다. 또한 부서에서 운영하는 정보시스템의 메뉴(또는 기능) 사용률을 점검하고, 사용 빈도가 낮거나 불필요한 메뉴는 비활성화, 통합 등 적절한 개선 조치를 마련하여 시행하여야 한다.

3. 감사결과 확인된 문제점

그런데 회사의 「정보화업무절차」 제24조(정보시스템 운영성과 측정) 제1항에 따라 운영일로부터 1년이 경과한 정보시스템을 대상으로 운영성과를 측정하게 되어 있음에도 불구하고, IRM²⁾에 등록된 시스템만 점검을 수행하고, 등록되지 않은 시스템은 별도로 점검하지 않고 있다. 그 결과, IRM 미등록 시스템의 경우 감사 대상 기간(2022.7.1. ~ 2025.6.30.) 동안 미사용 상태인 시스템에 대해 점검 또는 사용 부서 대상 시스템 활용 여부 확인 등의 조치가 이루어지지 않았으며, [그림 1]과 같이 ▶시스템의 경우 0000.0월부터 0000.0월 간 신규 데이터 입력이 0건에 불과할 정도로 사용률이 극히 저조함에도 불구하고, 이에 대한 정비, 개선 또는 폐기 검토가 이루어지지 않았다. 이는 정보시스템 운영 실적에 대한 체계적인 점검 및 관리가 미흡함을 나타낸다.

2) IRM(정보자원통합관리) : 정보화 사업이 조직전략과 목표에 부합하도록 추진하기 위해 전자정부아키텍처(EA) 기반으로 IT자원을 효과적으로 통제하고 관리하는 시스템

[그림 1] ▶시스템 데이터 입력 건수

(생 략)

또한, [표 1]과 같이 일부 시스템에서도 사용되지 않거나, 활용도가 매우 낮은 메뉴(게시판) 및 기능을 다수 확인하였다.

[표 1] 정보시스템의 미사용 메뉴(게시판) 및 기능

담당부서	정보시스템	메뉴(게시판)/기능	비고
(생 략)			

결과적으로, 미사용 또는 저활용 정보시스템 및 메뉴에 대한 체계적인 관리, 점검, 폐기 절차가 운영되지 못하고 있어, 정보자산의 효율적 운영과 관리 측면에서 개선이 시급하다.

관계부서 의견 및 검토결과 ♣실은 회사 사규 「정보화업무절차」를 정비하고, 주기적으로 정보시스템 운영성과를 측정하겠다고 하였다.

♣실과 ♠실은 미사용 메뉴 및 미사용 게시판에 대하여 최근 3년 이내 활용이 없는 경우 비활성화 방안을 마련하겠다고 답하였다.³⁾

3) 0000.00.0. 문답확인서 “

조치할 사항 ♣실장은

① 「정보화업무절차」 제24조(정보시스템 운영성과 측정)에 운영성과 측정의 점검주기를 명확히 명시하시기 바랍니다. 【개선요구】

② 「정보화업무절차」 제24조(정보시스템 운영성과 측정) 제1항에 의거 운영 개시일로부터 1년이 경과한 시스템의 운영성과를 측정하고, 그 결과에 따라, 정보시스템의 ‘유지’, ‘기능고도화’, ‘전면재개발’, ‘통폐합’, ‘폐기’ 등의 개선방안을 수립하여 이행하시기 바랍니다. 【통보】

③ ♣실장, ♠실장은 운영 중인 정보시스템(■, ▼시스템)과 관련하여 장기 미사용 메뉴의 활용 필요성을 검토하여 해당 메뉴(기능)의 유지/통폐합/폐기 등 개선방안을 마련하시기 바랍니다. 【통보】

(답 0-0)

- 미사용 메뉴 및 미사용 계시판에 대하여는 최근 3년 이내 활용이 없는 경우 비활성화 방안을 검토할 예정임.
- 일부 미사용 메뉴 중, 설계 부서 또는 타 분야가 해당 분야의 업무수행을 위해 운영중인 메뉴이며, 해당 부서/분야에 활용여부를 확인하여 비활성/활성 여부를 검토할 예정임 .
- 또한, ☆본부는 이전 등록 자료에 대해서도 일부 활용을 요청하는 경우가 있어 데이터 주관 부서와의 협의가 필요한 상황임.”

일련번호	2025-41
------	---------

상 임 감 사 권 고(3), 통 보(2)

제 목 : 전사적 관점의 정보화기본계획 수립 미흡

조 치 부 서 : ♣실, ♥실, ●연구소, ♠실

내 용

1. 업무 개요

♣실은 회사의 전산 인프라 및 정보시스템 운영을 종합적으로 지원하기 위해 3년 단위로 정보화기본계획¹⁾을 수립하고 있으며, 해당 계획은 전사적인 정보화 전략의 방향성을 제시하는 기초 자료로 활용되고 있다.

IT관련 부서(♠실, ♥실, ●연구소) 등은 정보화 계획을 작성하여 ♣실에 제출하며, ♣실은 이를 종합·조정하여 정보화기본계획 수립에 반영한다.

2. 관계법령 및 판단기준

「정보화업무절차」 제4조(기본계획의 수립) 제2항에 따르면 각 소관부서는 주관부서의 지침에 따라 소관부서 정보화계획을 작성하여 주관부서에 제출하며, 주관부서는 이를 전사 정보화기본계획 수립 시 반영하게 되어있다. 동 절차 제5조(연간정보화계획의 수립)에 따르면 주관부서는 각 소관부서의 연간정보화계획을 종합하여 전사 연간정보화계획을 수립하고 전결권한자의 승인을 받아 확정하여야 한다.

1) 「정보화업무절차」 개정(0000. 0. 00.) 이후 중장기전산화계획은 정보화기본계획으로 변경되었음

따라서 소관부서인 IT관련부서들은 정보화계획을 작성하여 주관부서인 ♣실에 제출하여야 하며, ♣실은 이를 종합하여 전사 정보화기본계획 수립에 반영하고 전사 연간정보화계획을 수립·확정 하여야한다.

3. 감사결과 확인된 문제점

그런데 0000년에 수립된 「정보화기본계획(0000 ~ 0000년)」을 분석한 결과, [표 1]과 같이 계획의 대부분이 ㉠실²⁾과 ㉡실³⁾의 업무 중심으로 구성되어 있으며, ♠실 ㉢팀 등 기타 IT 관련 부서⁴⁾의 정보화 추진계획 및 과제가 충분히 반영되지 않았다.

특히, ☆본부 ▼시스템(◆)은 0000년에 ♠실에서 자체 개발하여 현재까지 내부인력만으로 유지보수를 수행하고 있으나, 시스템의 노후화, 유지보수가 가능한 인력부족⁵⁾과 보안취약점⁶⁾ 등의 문제가 있다. 그러나, 이에 대한 개선과제(개선 로드맵, 예산반영 등)이 정보화기본계획에 포함되지 않아, 체계적인 대응이 이뤄지지 않고 있다.

더불어 회사에서는 0000.00.0.에 ☎⁷⁾ 서버의 디스크 용량 초과로 인한 데이터베이스 접근 불가로 ☞시스템 장애가 발생하였으며, 0000.0.0. 데이터베이스 서버 장애로 인해 ☞시스템이 7시간 동안 중단되는 사고가 재발

2) 0000.0.0. 「직제규정시행세칙」이 개정됨에 따라 ㉠실은 ♣실과 ♥실로 각각 이관됨

3) 0000.0.0. 「직제규정시행세칙」이 개정됨에 따라 ㉡실은 ㉠실의 ○팀과 ㉣팀과 통합되어 ♣실로 개편됨

4) 0000.0.00. 「직제규정시행세칙」개정에 따른 기구표에 IT관련 부서는 ♠실, ㉡실, ㉤실, ♥실, †실(㉢팀)이 있음

5) 개발가능한 인력은 ㉡장 포함 6명이며, ㉡장을 제외한 5명은 업무를 맡은 지 5년 이내의 직원으로 업무 숙련도가 낮음.
☆본부 ▼시스템은 0000년대 개발 방식(PL/SQL, Xplatform, Miplatform 등)으로 개발되어 있어 유지보수 인력 확보가 힘들며, 신입사원을 교육시켜 실무에 투입하기까지 시간이 많이 걸림

6) ◆ 시스템 보안등급 관리 부적정 처분요구서 참조

7) ☎ : 회사의 †시스템

하였다. 또한, 정부 차원에서도 2025.9.26. 국가정보자원관리원 전산실 화재 사고로 다수의 정부 정보시스템이 마비되는 등 정보시스템 중단에 따른 업무 중지 리스크가 현실화되고 있다. 이러한 상황에서 정보시스템 장애시 업무의 연속성을 확보하기 위한 재해복구(DR) 체계의 중요성은 더욱 커지고 있으나, [표 1]과 같이 정보화기본계획(0000 ~ 0000년)에 ‘재해복구(DR) 센터 구축’ 과제가 명시되어 있었음에도, 해당 과제의 내용 및 이행이 충분하지 않아 0000.0.0. 시스템 장애시 업무 연속성 확보에 실패하는 결과가 초래되었다.

[표 1] 정보화기본계획(0000 ~ 0000년)의 이행과제 목록

대분류	중분류	이행과제	관련부서 ⁸⁾
(생 략)			

8) 부서개편 이전 기준(0000.0.0. 부서개편)

이처럼 정보화기본계획이 冊실과 冊실 일부 IT 부서(현, ♣실 및 ♥실 ☒팀)의 업무에 편중되어 수립됨에 따라, 전사적 차원의 정보화 전략으로서의 포괄성과 균형성이 결여된 한계가 있으며, 핵심 정보자산 보호 및 업무 연속성 확보를 위한 계획 수립이 미흡한 만큼 전사적이고 포괄적인 정보화 전략 수립이 시급한 실정이다.

관계부서 의견 및 검토결과 ♣실은 정보화기본계획 수립 시 회사 전 부서를 대상으로 과제 수립을 위한 협조 요청을 발송할 계획이며, 회사 정보화기본계획 추진전략에 부합하는 과제를 선정할 계획이라고 답하였다.⁹⁾

조치할 사항 ♣실장은

- ① 향후 정보화기본계획 수립 시, 주요 IT 부서(♠실, ♥실, ●연구소 등)에서 제출한 정보화 추진 과제를 면밀히 검토하고, 전사적 파급효과, 중요도, 시급성 등을 고려하여 우선순위기반의 균형 잡힌 종합적인 계획을 수립하시기 바랍니다. **【권고】**
- ② 국가정보자원관리원 전산실 화재(2025.9.26.)로 인한 정부 전산시스템마비 사고를 참고하여, 회사의 핵심 시스템 이중화, 재해복구 체계 구축, 데이터 백업 및 복구 인프라 강화 등 업무 연속성 확보를 위한 과제를 차기 정보화기본계획에 최우선 순위로 반영하고 적극 추진하시기 바랍니다. **【통보】**

9) 0000.0.00. ♣실 답변서 “정보화기본계획(0000~0000) 수립 시에도 회사 전 부서로 과제 수립을 위한 협조 요청을 발송할 계획이며, 회사 정보화기본계획 추진전략에 부합하는 과제를 선정할 계획입니다.”

③ ♠실의 ↑시스템(◆) 고도화 계획을 차기 정보화기본계획에 최우선 과제로 반영하고, ↑시스템 고도화 사업이 성공적으로 이행될 수 있도록 적극 지원해 주시기바랍니다. **【통보】**

④ ♥실장, ●연구소장은 부서의 정보화 수요 등을 면밀히 점검하고, 시스템 개선 계획 등을 체계적으로 도출·제안하여 2026년에 수립 예정인 차기 정보화기본계획에 충실히 반영되도록 적극 협력하시기 바랍니다. **【권고】**

⑤ ♠실장은 ☆본부의 ↑시스템 고도화를 위한 실행 계획을 수립하고, 해당 과제가 차기 정보화 기본계획에 최우선 과제로 반영될 수 있도록 제안하시기 바랍니다. **【권고】**

일련번호	2025-42
------	---------

상 임 감 사

시 정, 통 보

제 목 : ♠시스템 본부권한 담당자의 조회 및 관리 권한 부적정

조 치 부 서 : ♣실

내 용

1. 업무 개요

◇처는 1급 이상 직원의 성과 평가를 체계적으로 관리하기 위해 0000년부터 ♠시스템을 운영하고 있으며, ♣실은 유지보수 업무를 담당하고 있다. ♣실은 ♠시스템의 원활한 운영을 위해 본부장 ☆기술서 입력, 피평가자의 ☆기술서 입력 문의 처리, 미입력자 확인 등의 업무를 수행할 수 있도록 본부 권한 담당자 기능을 제공하고 있으며, 각 본부 담당자가 시스템 내에서 평가 진행 상황을 관리하고 이행할 수 있도록 권한을 부여·운영하고 있다.

2. 관계법령 및 판단기준

「행정기관 정보시스템 접근권한 관리 규정」 제13조(접근권한 부여 기준) 제1항에 따르면, 정보의 중요도 및 업무 필요성에 따라 접근권한의 범위를 차등화하여 부여하여야 하며, 최소 권한 원칙(Minimum Privilege)에 따라 불필요한 정보 접근을 제한해야 한다. 또한, 「정보화자산운영업무절차」 제18조(정보화자산 보안) 제2항에 따르면, 소관부서는 해당 운영 시스템의

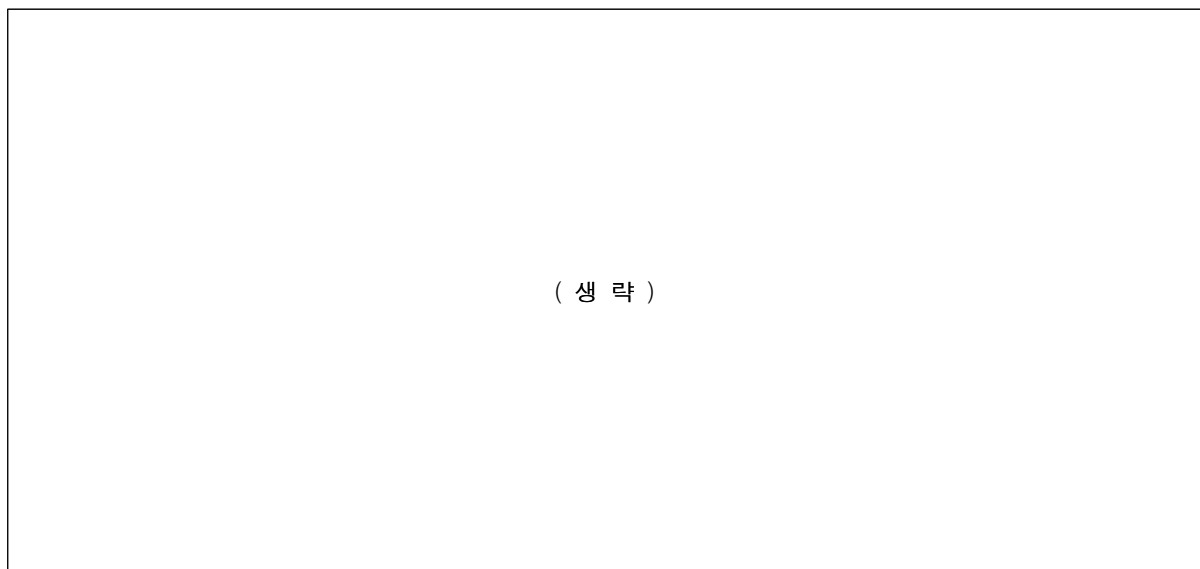
사용자별 이용 권한을 정의하여 사용자의 직무에 따른 정보 열람 범위를 설정한 후 등급을 부여하여 관리해야 한다.

따라서 ◇처와 ♣실은 ♠시스템 운영 시, 본부권한 담당자에게 해당 본부의 정보에 한정된 조회 및 관리 권한만을 최소한으로 부여하여야 하며, 타 본부의 평가 정보에 대한 접근이 불가능하도록 권한을 철저히 제한함으로써 정보의 기밀성과 보안성을 확보하고, 시스템을 안정적으로 운영해야 한다.

3. 감사결과 확인된 문제점

그런데 [그림 1]과 같이 본부권한 담당자가 ♠시스템의 ‘→평가’ 메뉴 ‘⚙기술서 입력’ 화면에서 본인의 사번이 아닌 타 본부 담당자의 사번을 임의로 입력하는 경우, 시스템이 이를 정상 사용자로 인식하여 [그림 2]와 같이 입력한 사번에 해당하는 담당자가 관리하는 본부의 평가 대상자 정보를 조회할 수 있는 권한이 부여되는 것으로 확인되었다.

[그림 1] ♠시스템의 →평가-⚙기술서 입력 화면



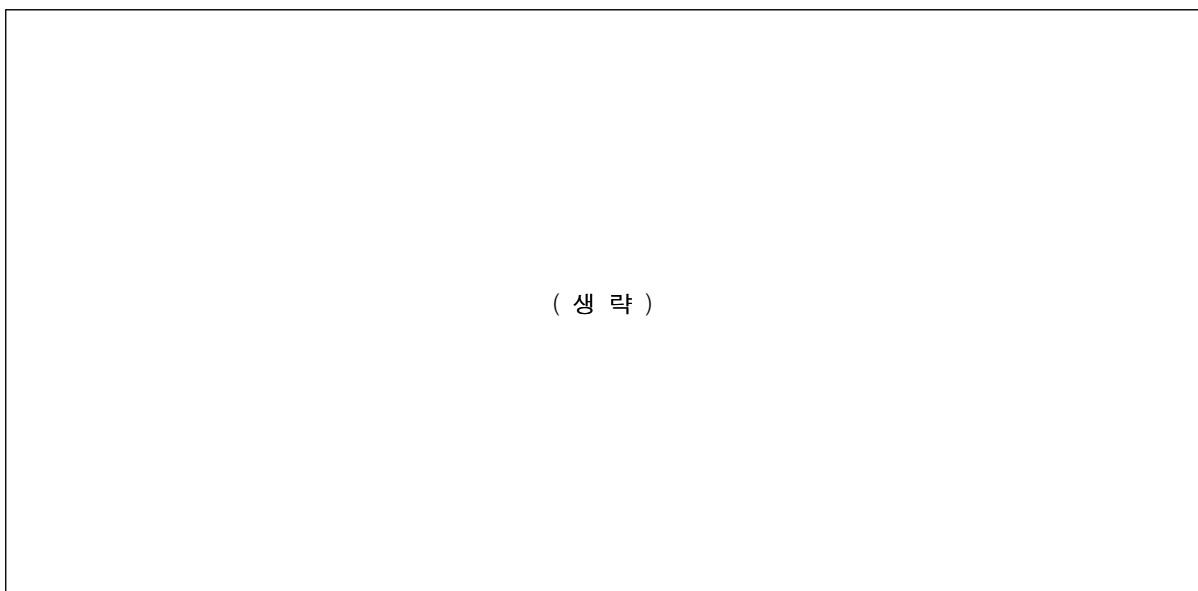
[그림 2] 사번 변경 후, 타 본부 평가 대상자 조회 화면



이는 최소 권한 원칙 및 직무 기반 접근 통제에 위배되는 사항으로, 본부 권한 담당자의 접근 범위가 자신이 소속된 본부의 정보로 제한되지 않고, 사번을 임의로 변경함으로써 타 본부의 민감한 인사 평가 정보에 접근 가능한 보안 취약점이 존재함을 의미한다.

문제가 되는 화면의 소스코드를 확인해 본 결과, [그림 1]의 ‘❖기술서 입력’ 화면에서 사번을 임의로 변경할 경우, [그림 3]과 같이 시스템 내 글로벌 변수¹⁾인 ‘●’에 변경된 사번이 저장되어 실제 로그인 사용자가 아닌 변경된 사번의 권한을 가지는 것으로 확인되었다.

[그림 3] ❖기술서 입력화면에서 사번 변경시 저장되는 소스코드



1) 정보시스템에서 변수는 글로벌 변수와 로컬 변수가 있으며, 글로벌 변수는 전체 시스템에 영향이 있지만 로컬 변수는 해당 화면에만 영향이 있음

사번 변경 후 [그림 4]과 같이 “관리자 > ✎보고서” 메뉴에서도 소속 본부의 타 본부의 ➔평가 정보를 열람할 수 있는 것으로 확인됐으며, 이는 시스템 상에서 본부 간 정보 격리가 제대로 이루어지지 않고 있음을 의미한다.

[그림 4] 사번 변경 후 타 본부 평가결과서 조회 화면



그 결과, 본부권한 담당자는 자신의 업무 범위를 초과하여 타 본부 소속 직원의 민감한 ➔평가 정보를 무단으로 열람할 수 있는 보안 취약점이 존재하며, 이는 정보보안 관리의 핵심 원칙인 최소 권한 원칙 및 업무 필요성 기반 접근 통제에 명백히 위배되는 사항으로 판단된다.

해당 문제는 단순한 기술적 오류를 넘어, 내부 정보 유출 가능성을 높이는 중대한 보안 결함으로, 조속한 시스템 개선 및 권한관리 로직 재설계가 필요하다.

관계부서 의견 및 검토결과 ♣실은 본부권한 담당자 권한이 해당 화면 내에서만 유효하도록 설계되었으며, 타 본보 정보접근이 가능한 사유는 시스템 상 기능 구현 오류로 감사실 지적 내용에 대해 시스템 설계 취지에 맞게 조치하겠다고 답하였다.²⁾

2) 0000. 0. 00. ♣실 답변서 ““➔평가 > ✎기술 > ✎기술서 입력(000/x_XXXXX000)’ 화면에서 타 직원의 사번을 입력하여 조회 및 입력하는 기능은 본부권한 담당자에게 부여된 권한으로 본부장 ✎기술서 입력, 본부내 피평가자의 ✎기술서 입력 문의 대응 및 ✎기술서 미입력자 확인 등의 용도로 사용하고 있습니다.
다만 ♣시스템의 기능 확인 결과 본부권한 담당자 권한의 기능은 해당 화면 내에서만 작동하여야 하지만, 해당 화면을 벗어나 ♣시스템 전체에 영향을 미치는 것으로 확인되었습니다. 이는 ♣시스템의 구현 오류로 파악되며 해당 오류는 취지에 맞게 조치하도록 하겠습니다.”

조치할 사항 ♣실장은

① ♠시스템 내 본부권한 담당자에게 부여된 접근권한에 대해 설계 취지 및 최소 업무 필요성 원칙에 부합하도록 기술적 조치를 시행하고, ◇처에 그 결과를 통보하시기 바랍니다. 【시정】

② ♠시스템과 유사 시스템(인턴♣, ✕평가 등)에 대해 설계 취지와 달리 과도하거나 불필요한 권한이 부여된 기능이 존재하는지 여부를 소관부서인 ◇처와 협의하여 점검하고, 과도하거나 불필요한 권한을 조정하시기 바랍니다. 【통보】

일련번호	2025-43
------	---------

상 임 감 사 통 보(2), 개선요구

제 목 : ◆ 시스템 신입 및 퇴직자 권한관리 부적정

조 치 부 서 : ♠실, ◇처, ♣실

내 용

1. 업무 개요

♠실은 「직제규정시행세칙」에 따라 ☆본부 ○시스템(이하 ‘◆1) 시스템’)의 운영업무를 수행하고 있다. ☆본부에 신규입사 또는 전입되는 직원에 대해서는 “◆ 사용신청서”를 접수한 후 업무 필요성 및 직무 범위를 검토하여 정보시스템 접근권한을 부여하고 있으며, 퇴직 또는 타 본부로 전보되는 직원에 대해서는 “▼시스템 사용 중지 신청서”를 접수받아 정보시스템 접근권한을 회수하고 있다.

2. 관계법령 및 판단기준

☆본부 설계관리절차서(Engineering Procedure, EP) 0.00(Rev. 00)에 0.0 설계문서 설계전산화에 따르면 설계담당자는 EP 0.00 “Design Documents”의 요건 및 기준에 따라 문서를 작성하고, ▼시스템에 문서를 등록해야 한다. 또한 설계문서 검토 및 최종 승인 등이 전자결재로 되어있어 ◆ 시스템을 사용하여 업무를 진행하고 있다.

1) ◆ : ☆본부의 사업 수행을 위해, 별도로로서 구축, 운영 중인 ○시스템

또한, 「사용자보안 관리지침」 제14조(퇴사 및 계약해지) 제3항에는
직원이 퇴사 또는 계약 해지 시 해당 직원의 시스템 권한을 삭제하게 되어있으며,
ISMS-P²⁾ 2.5.1 사용자 계정 관리, 「개인정보보호법」 제29조 (안전조치의무),
「전자금융감독규정」 제13조(전산자료 보호대책), 「신용정보업감독규정」
별표3 기술적·물리적·관리적 보안대책 마련 기준 등에서 퇴직 등의 인사 변동 시
즉시 권한을 회수하게 되어있는 등 인사 변동시 즉시 접근권한을 회수하도록
규정하고 있다.

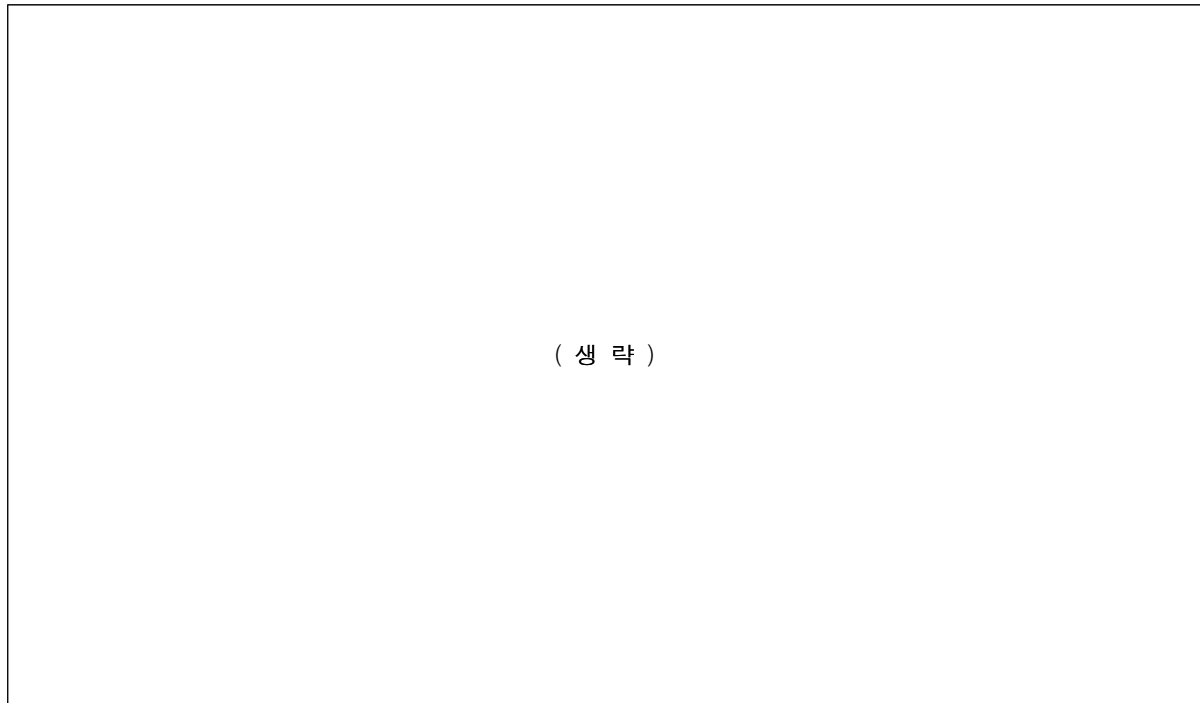
따라서 ♠실은 신규 입사자 또는 전입 직원에 대해 업무 수행 필요성
에 따라 ◆ 접근권한을 신속히 부여하고, 퇴직 또는 전보 직원에 대해서는
즉시 사용 권한을 회수하여 미사용 계정의 남용 및 정보 유출 위험을 방지
해야 한다.

3. 감사결과 확인된 문제점

그런데 ☆본부에 신입사원 또는 전입 직원이 발생한 경우, ◆ 시스템
사용을 위해 [그림 1]과 같이 신청자가 ㄴ장 전결로 “◆ 사용신청서”를 작
성하여 ㄹ팀 전산담당자에게 메일로 제출한 후 담당자가 4단계의 권한
등록을 수작업으로 진행하고 있다. 이러한 전체 프로세스가 인사 DB활용
등 시스템 간 연계 없이 수작업에 의해 의존하고 있으며, 그 결과 [표 1]과
같이 권한 부여 지연 및 입력 오류 등의 문제가 확인되었다.

2) ISMS-P : 정보보호 및 개인정보보호 관리체계 인증, 정보보호 및 개인정보보호를 위한 일련의 조치와 활동이 인증기준에
적합함을 인터넷진흥원 또는 인증기관이 증명하는 제도

[그림 1] 신입사원 또는 전입 직원의 4단계 권한 등록 프로세스



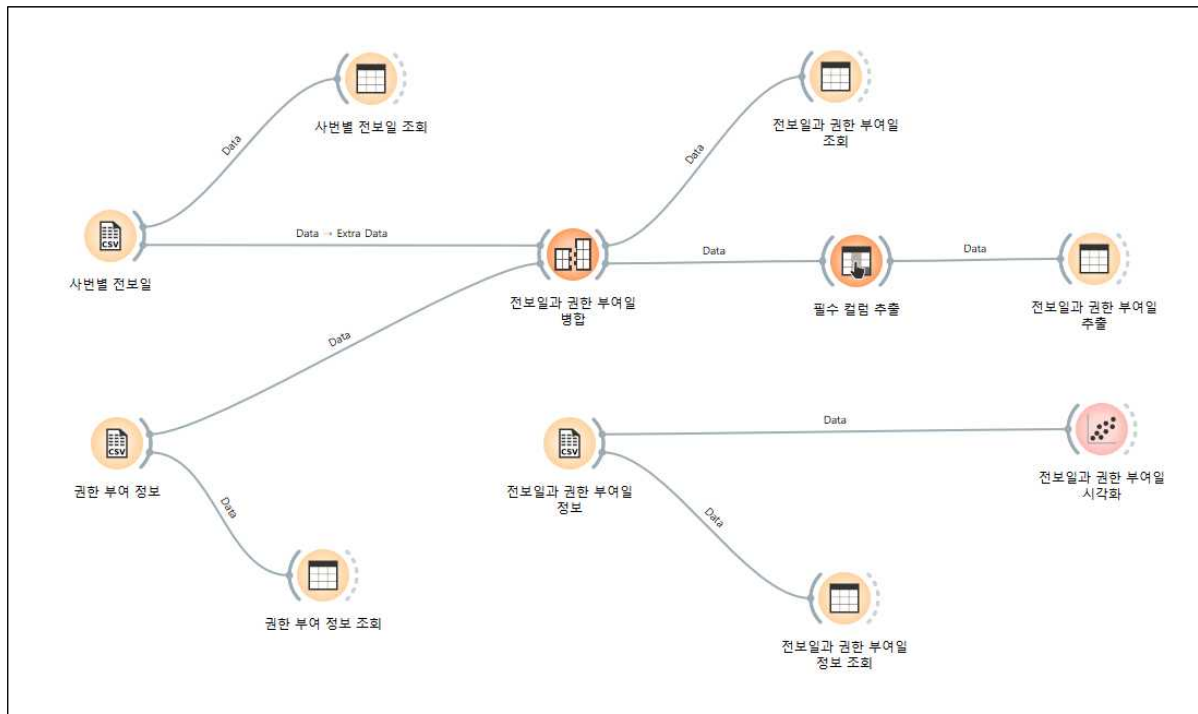
(생 략)

[표 1] 입력오류 및 문제점

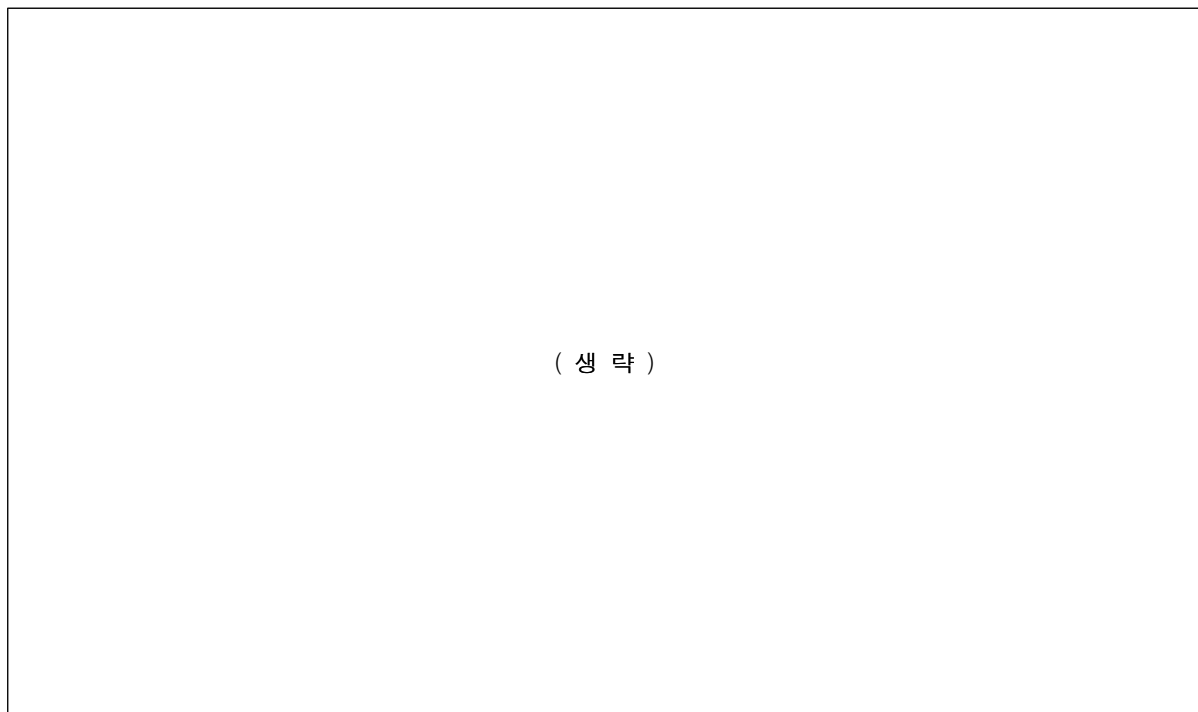
순번	입력오류 및 문제점	해결방안
(생 략)		

◆ 시스템의 권한 정보와 0000.0월 이후 신규입사자 정보 데이터를 기반으로 전보일과 권한부여일 차이를 데이터 분석도구 Orange3를 활용하여 [그림 2]과 같이 분석한 결과, [그림 3]과 같이 산점도 형태로 시각화할 수 있었다.

[그림 2] Orange3 워크플로우(전보일과 권한부여일 차이)



[그림 3] Orange3로 분석한 전보일과 권한부여일 시각화



[그림 3]은 $y = x$ (y: 권한부여일, x: 전보일)을 기준으로 삼아 시각화하였는데, 각 데이터 포인트가 이 기준선 상에 위치할 경우 전보일 당일 즉시 권한이

부여된 것을 의미한다. 반면, $y = x$ 선의 위쪽에 위치한 데이터는 권한 부여일이
입사일보다 지연된 것을 의미하며, 특히, $y = x$ 선으로부터 수직 거리가 멀수록
입사일과 권한부여일 간의 차이(권한부여 지연 기간)가 크다는 것을 의미한다.

[표 2] 전보일과 권한부여일 차이 상세내역

순번	사번	등록일	입사일	차이
(생 략)				

순번	사번	등록일	입사일	차이

분석결과 [표 2]에서 확인할 수 있듯이 신규 직원이 ◆ 권한을 부여받기까지 평균 00일, 최장 00일이 소요된 것을 확인하였다.

실제로 감사인은 본 감사 수행을 위해 0000.0.00.(월)에 ◆ 시스템 접근 권한을 신청하였으나, 권한이 부여된 시점은 0.0.(수)로, 0일이 소요되어 신속한 접근권한 부여가 되지 않았다. 또한, 권한 부여 과정에서 내부 설정 오류로 인해 ■의 정보가 ◆ 시스템에 정상적으로 전달되지 않는 등 권한 관리 프로세스가 수동적 방식으로 운영되고 있음을 파악하였다.

그 결과, 신규 입사 또는 전입 직원은 권한이 부여되기 전까지 ◆ 시스템에 접근할 수 없어, 설계 문서 확인 등 핵심업무 수행이 초기 단계에서부터 ◆ 시스템을 활용한 업무 수행이 제한되는 실정이다. 이는 조직의 업무 효율성 저하뿐 아니라, 보안 정책상 요구되는 적시 계정 관리 및 최소 권한 부여 원칙의 미준수로 이어지는 구조적 문제로 판단된다.

또한, 직원이 퇴직 또는 타 본부 전보 시에는 해당 직원이 직접

[그림 4]와 같이 “▼시스템 사용 중지 신청서”를 작성하여 1장 전결 후, 메일로 4팀에 제출하면, 권한부여 담당자가 4단계의 권한 중지 절차를 수작업으로 수행하고 있다.

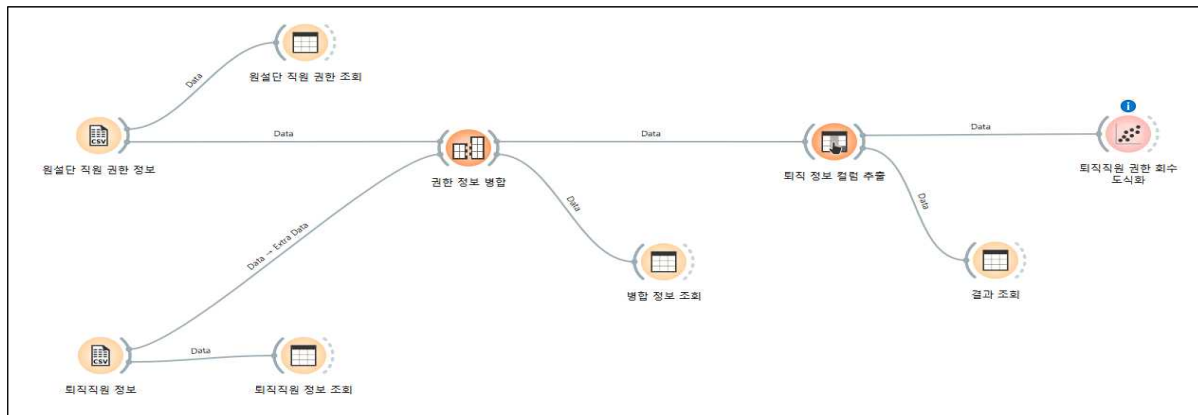
[그림 4] 퇴직 또는 전보 직원의 4단계 권한중지 프로세스



◆ 시스템의 권한 정보와 퇴직자 정보 데이터를 기반으로 0000.0월부터 0000.0.00.까지 퇴직일과 권한 회수일 간의 차이를 Orange3를 활용하여 데이터³⁾를 분석한 결과, [그림 5]와 같이 시각화할 수 있었다. 분석 결과, [표 3]에서 확인할 수 있듯이 퇴직일로부터 권한 회수가 00일 이상 지연된 사례가 총 00건 발생하였으며, 최대 0000일(약 00년)이 경과한 후에야 권한이 회수된 사례도 존재하였다.

3) ▲실에서 제출한 데이터로 분석

[그림 5] Orange3 워크플로우



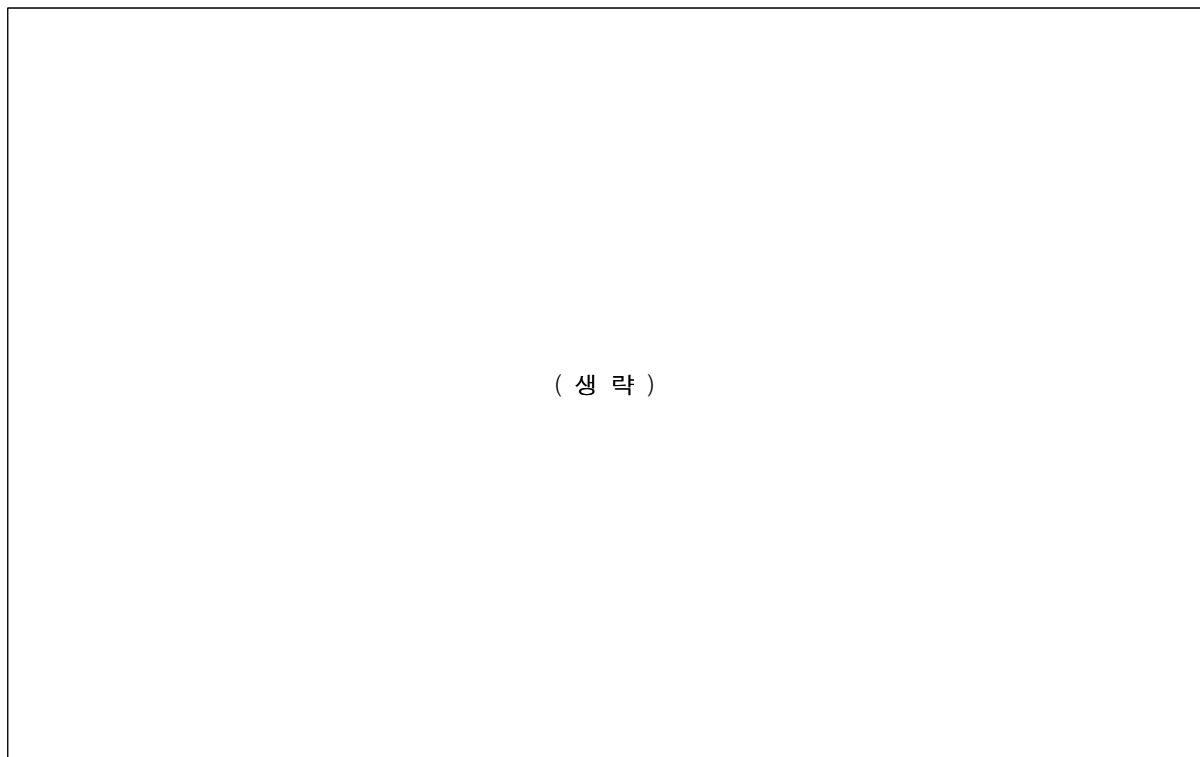
[표 3] 권한회수일이 퇴직일보다 00일 이상 명단

순번	사번	퇴직일	권한회수일	차이(일)
(생 략)				

Orange3 분석 결과를 바탕으로 한 [그림 6]은 $y = x$ (y: 퇴직일, x: 권한 회수일)을 기준으로 산점도를 구성하였으며, 이 기준선은 퇴직 당일 권한이 정상적으로 회수된 경우를 의미한다. $y = x$ 선 아래에 위치한 데이터는

퇴직 전에 권한이 회수된 경우로 계정관리가 사전에 적절히 수행된 것으로 판단할 수 있으며, 반면, $y = x$ 선 위에 있는 데이터는 퇴직 이후에 권한이 회수된 경우를 나타내며, 해당 기간 퇴직자의 계정이 시스템 내에서 유효한 상태로 남아 있었음을 의미한다. 특히, 선으로부터 수직 거리가 멀수록 권한 회수 지연 기간이 길어, 보안 관리 소홀의 정도가 심각함을 시사한다.

[그림 6] Orange3로 분석한 퇴직일과 권한회수일 시각화



또한, 현재 권한 회수 프로세스는 인사 DB의 퇴직 정보 등 신분 데이터와 시스템 간 연계가 이루어지지 않고, 오로지 사용자의 직접 신청에 의존하고 있다. 이로 인해 퇴직자가 사용 중지 신청서를 제출하지 않거나, 제출이 지연되는 경우, IT팀은 계정 비활성화 조치를 인지하지 못하거나 지연할 수밖에 없어, 미사용 계정이 시스템 내에서 장기간 잔존하게 되며 이로 인한 정보 유출 위험이 발생하고 있다.

관계부서 의견 및 검토결과 ♠실은 신규 전입자의 전보일과 ◆시스템 권한부여일 간 차이가 발생하는 주요 원인으로 신규직원의 “◆사용신청서” 제출 지연, 담당자의 메일 확인 지연, 업무량 증가에 따른 처리 지체 등을 설명하였으며, 향후, 회사의 인사 DB와 ◆시스템의 기본적인 사용자 정보 등록에 대하여 연동을 검토하겠다고 밝혔다.⁴⁾

또한, 퇴직자가 발생한 후 권한 회수까지 00일 이상 소요되는 원인에 대해서는 일부 퇴직자가 “▼시스템 사용 중지 신청서”를 제출하지 않아 ♠실이 퇴직 사실을 즉시 인지하지 못해 발생한 문제이며, 본사 인사 DB와 연동을 통해 본사와 동일한 방법으로 퇴직자에 한하여 자동 일괄 퇴직 처리(계정 비활성화)하는 기능을 검토하겠다고 밝혔다.⁵⁾

4) 0000.00.0. 문답확인서 “

(답 0-0)

- 일반적으로 신규 직원의 ☆본부 전보일과 ◆ 권한 부여일 간 차이 발생 사유는 아래와 같음
 - 신규 직원의 입사일 이후 신청 요청일 지연에 따른 차이
 - ■팀 업무 소요 일정 지연 (Ex. 담당자 메일 확인 지연, 업무량 증가에 따른 권한 부여 지체 등)
- 상기에서 언급한 바와 같이, 신규 직원의 경우 업무 수행 전에 필요한 교육 및 훈련을 받아야 하며, □업무 수행 여부에 따라 ▼시스템의 사용여부 및 사용 시작일이 다를 수 있음
- 또한 직원별로 부여받는 권한이 다르며 이는 소속 부서의 ㄴ장 또는 ㄸ책임자 판단하에 전적으로 이뤄져야 함.
- 사용자정보 관리 테이블은 회사의 인사 DB 정보를 연계하여 기본적인 사용자 정보 등록에 대하여 연동을 검토할 예정이며, 현재 주관부서에 인사DB 활용 권한을 요청한 상태임”

5) 0000.00.0. 문답확인서 “

(답 0-0)

- ☆본부 ■팀은 직원의 인사변경과 관련하여 ☆본부내 주관부서에 인사 정보를 제공받는 절차를 여러차례 요청하였으나 정보제공이 원활하지 않았음,
- 정보시스템 운영을 위하여 퇴직, 본부 이동시 사용자의 신청/중지 정보가 필요하여 사전에 중지요청서를 신청하도록 교육 및 안내메일을 통해 요청하였으며, 요청된 신청서를 통해 사용자 등록 및 사용 중지 여부를 관리하였음,
- 사용자 정보시스템 사용 중지는 사용자가 퇴직 전 “▼시스템 사용 중지 신청서”를 요청하고 이를 기반으로 관리하는 것이 원칙이나, 퇴직자의 중지 신청이 원활하지 않은 상태(재택근무 등의 사유로 미신청 퇴직)가 발생하기도 함.
- 상기와 같은 경우는 정보시스템 운영 부서(■팀)에서 퇴직 여부를 즉시 알 수 있는 정보가 없으며, 퇴직 이후 인사 발령 공문 확인 또는 퇴직자 동일 근무 부서의 중지 요청 내용에 따라 사용자의 퇴직 여부 및 시스템 중지 처리를 수행하기도 함.
- 또한, 초창기 정보시스템 사용자 테이블의 관리 항목에서 권한 회수일(XXX_XXXX)은 관리 항목에 미포함, 주관리 대상도 아니어서 사용자 사용/퇴직 유무(XXXXXX) 컬럼의 정보만 수정 관리하였음. 권한 회수일과 퇴직일 간의 차이가 나는 경우는 이에 해당한다고 판단함.
- 향후 이 건과 관련하여, 본사 인사 DB 연동을 통해 본사의 타 시스템과 유사한 방법으로 퇴직자에 한하여 자동 일괄 퇴직처리 하는 기능을 검토하여 신속한 퇴사 처리를 할 수 있도록 기능 변경 예정임.”

◇처 및 ♣실은 ♠실의 ☼시스템 연동 추진계획에 대해 적극 협력하겠다고 밝혔다.

조치할 사항 ♠실장은

① ☆본부 소속 신규직원의 ◇시스템 접근 권한이 신속하고 정확하게 부여될 수 있도록 인사 DB 연계 등을 포함한 개선방안을 마련하고 시행하시기 바랍니다. 【통보】

② 권한회수 지연 및 미사용 계정이 장기간 존재하는 취약점을 개선하기 위해, ☼시스템 DB와 연동하여 퇴직 또는 타 본부 전보 발생 시 권한을 즉시 회수할 수 있도록 ◇시스템을 개선하시기 바랍니다. 【개선요구】

③ ◇처장과 ♣실장은 ♠실이 ☼시스템과 ◇시스템 간 연동이 원활하게 이루어질 수 있도록, 인사DB 연동에 적극 지원하시기 바랍니다. 【통보】

일련번호	2025-44
------	---------

상 임 감 사 주 의, 시 정(2)

제 목 : ◆ 시스템 보안등급 관리 부적정

조 치 부 서 : ♠실

내 용

1. 업무 개요

♠실은 「직제규정시행세칙」 및 「회사 설계관리절차서」에 따라 ☆본부의 ▼시스템 개발 및 운영업무를 담당하고 있으며, 기술업무절차서 「사업문서 등급 및 이용 관리」에 따라서 ↑시스템(이하 ‘◆1) 시스템’)을 통해 설계도면, 계산서 등의 문서 생성과 검색·관리 등의 업무가 수행될 수 있도록 ◆ 시스템의 설계·개발·유지보수 업무를 수행하고 있다.

2. 관계법령 및 판단기준

회사 사규 「영업비밀보호관리규정」 제7조(영업비밀의 분류) 제1항²⁾에 따르면 영업비밀은 중요도와 가치의 정도에 따라 [표 1]과 같이 1급(별도관리자료), 2급(특별보호자료), 3급(일반보호자료)으로 구분하여 등급별로 차등 관리하도록 규정하고 있다.

1) ◆ : ☆본부의 사업 수행을 위해, 별도로써 구축, 운영 중인 ○시스템

2) 0000.0.0. 「영업비밀보호관리규정」 00차 개정에서 영업비밀 자료등급이 5등급에서 3등급으로 변경되었음

[표 1] 영업비밀보호관리규정 제7조(영업비밀의 분류)의 영업비밀

자료등급	자료구분	내용
(생 략)		

또한, [표 2]와 같이 ☆본부 기술업무절차서 「사업문서 등급 및 이용 관리」(TAP-00-00 Rev.00) 제4.1.2조 “사업문서 자료등급”에서도 동일하게 사업문서를 1급, 2급, 3급으로 분류하고 있으며, [표 3]과 같이 동 절차서 제 4.2조 “사업문서 자료등급별 이용”에 따라 자료 이용권한은 자료의 등급과 이용자의 직위 등에 따라 제한되어 있어 실무자는 종료사업문서 중 2급(특별보호자료)에 대해서는 열람만 허용되며, 출력과 저장은 제한되어 있다.

[표 2] ☆본부 사업문서 자료등급

자료등급	자료구분	사업문서
(생 략)		

[표 3] ☆본부 사업문서 자료등급별 이용권한

구분	자료등급	자료구분	이용권한		
			부서장	기타 직위자	실무자
(생 략)					

한편, 「소프트웨어 보안약점 진단가이드³⁾」 제3장 분석·설계단계 보안 항목 진단 1.9 보안기능 입력값 검증에서는 사용자의 역할 및 권한을 결정하는 정보는 반드시 서버 측에서 관리되어야 한다고 명시하고 있으며, 제4장 구현단계 보안약점 진단 15. 보안기능 결정에 사용되는 부적절한 입력값에서는 상태정보 및 민감한 정보는 클라이언트가 아닌 서버에 저장하고, 관련 보안 확인 절차 역시 서버에서 수행하게 되어있다. 이는 클라이언트에서 전달된 파라미터⁴⁾를 서버가 충분히 검증하지 않을 경우, 공격자가 사용자 권한 또는 역할을 나타내는 값을 임의로 조작하여 상승된 권한으로 시스템에 무단으로 접근하는 권한 상승(Privilege Escalation) 공격이 가능하기 때문이다.

따라서 ♠ 실은 ◆ 시스템 내에서 관리되는 사업문서에 대해 「영업비밀관리규정」을 준수하여 1급, 2급, 3급의 정확한 등급 분류를 적용하고, 문서 접근권한 및 등급 결정 정보가 클라이언트가 아닌 서버에서 안전하게 결정/관리되도록 시스템을 설계·개발·운영하여야 한다.

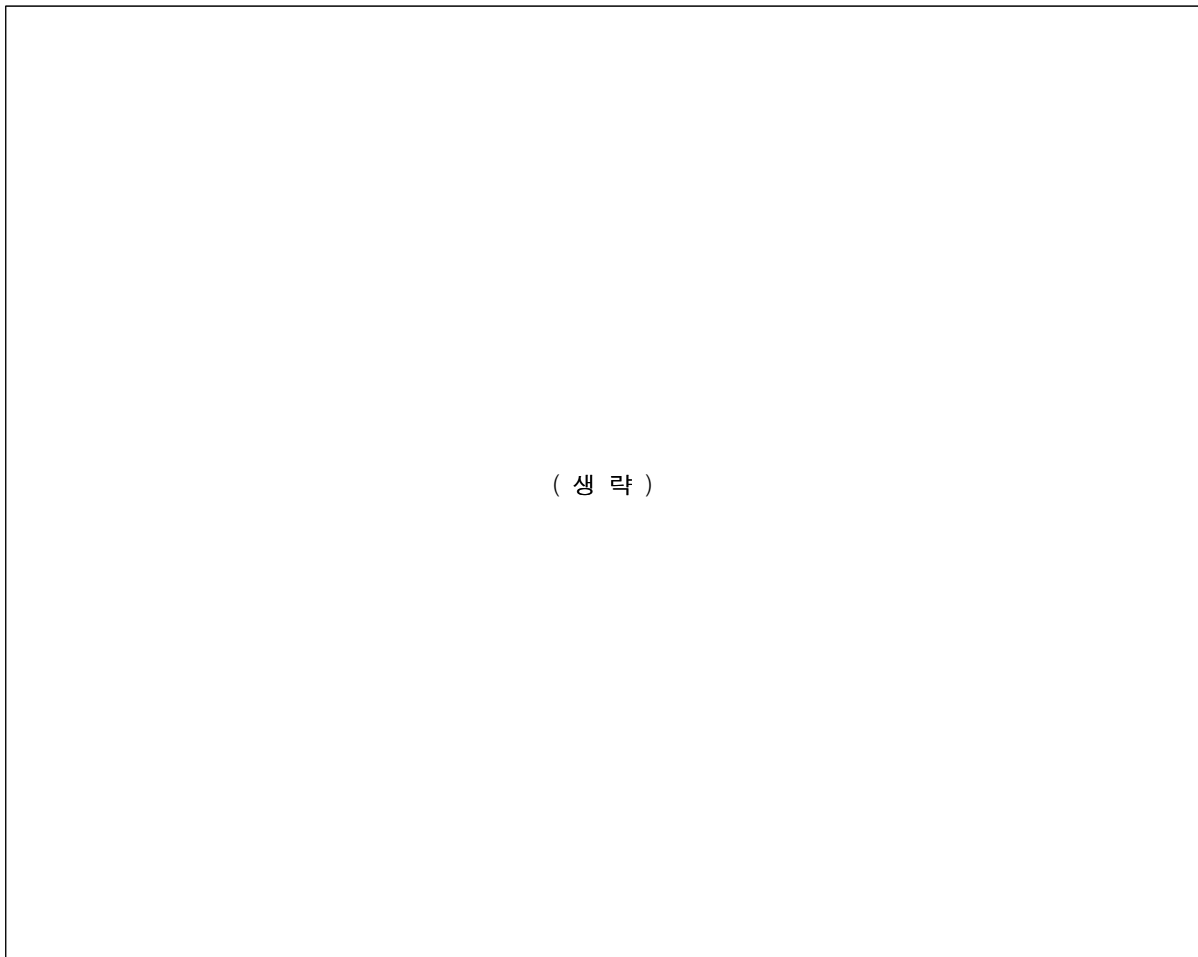
3) 소프트웨어 보안약점 진단가이드(2021, 행정안전부/한국인터넷진흥원) : 소프트웨어의 취약점을 완화시킬 수 있는 각 단계별 기술적 통제항목이 소프트웨어 개발에 올바르게 적용되었는지 진단하는 방법을 설명함

4) 파라미터 : 매개변수, 함수 내부로 전달되는 값을 가르키는 변수

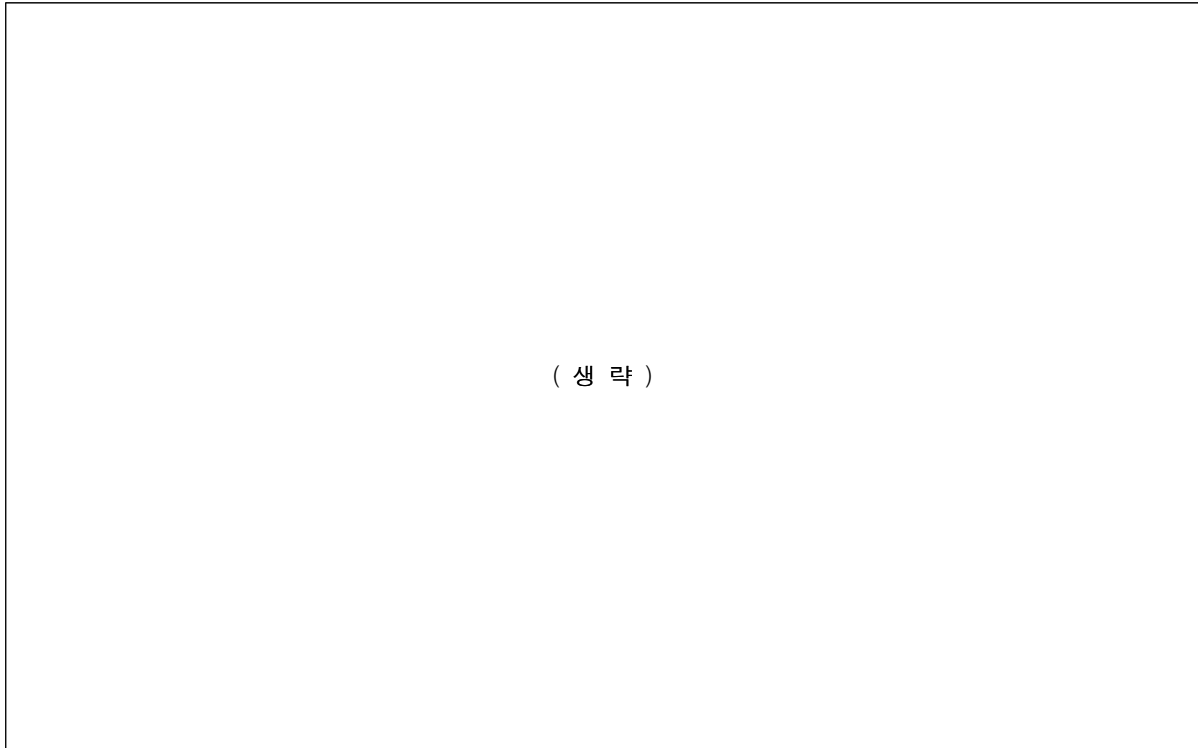
3. 감사결과 확인된 문제점

그런데 ◆ 시스템에서 현재 진행중인 ❖호기 사업의 설계도면(파일명: X-00X00-000-000-X00-XXX.pdf, 발행일: 0000. 0. 00.)을 확인한 결과, [그림 1]과 같이 시스템 화면상에는 자료등급이 ‘2급(특별보호자료)’으로 표시되고 있으나, 해당 문서를 출력하면 [그림 2]와 같이 ‘4급’ 자료로 오표기되는 등 시스템 내·외부간 등급 표기 불일치가 확인되었다. 해당 문서는 「영업비밀보호관리규정」 및 기술업무절차서 「사업문서 등급 및 이용 관리」(TAP-00-00 Rev.00) 개정(0000. 0. 00.) 이후에 생성된 자료임에도 불구하고, 「영업비밀보호관리 규정」에서 정한 등급 관리 기준과 다르게 운영되고 있었다.

[그림 1] 진행사업의 자료등급 2급자료 조회

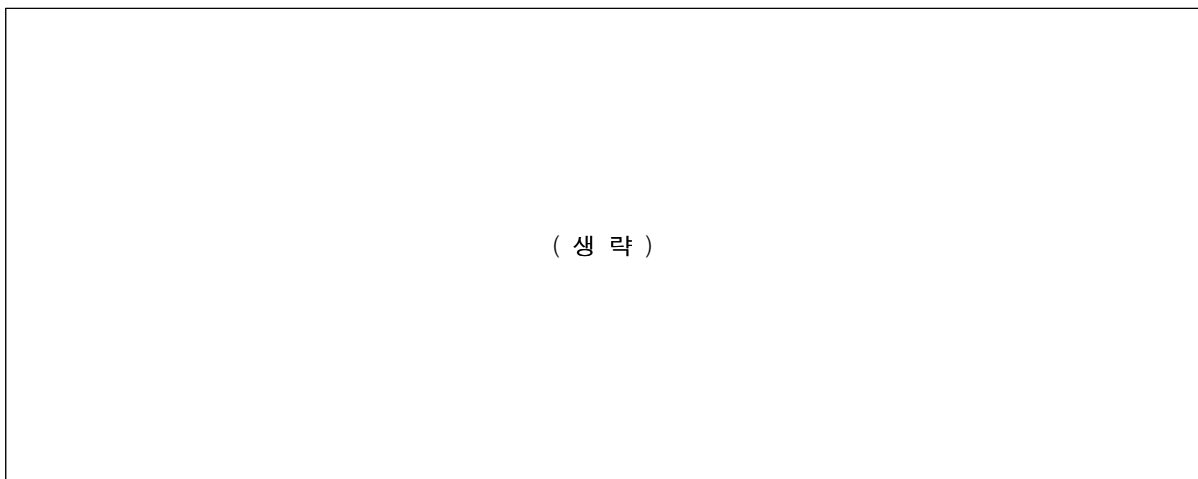


[그림 2] 자료등급 2급자료 출력물



◆ 시스템 자료이용신청서를 확인한 결과, [그림 3]과 같이 영업비밀이 1급, 2-5급으로 규정과 다르게 관리되고 있음을 추가로 확인하였다.

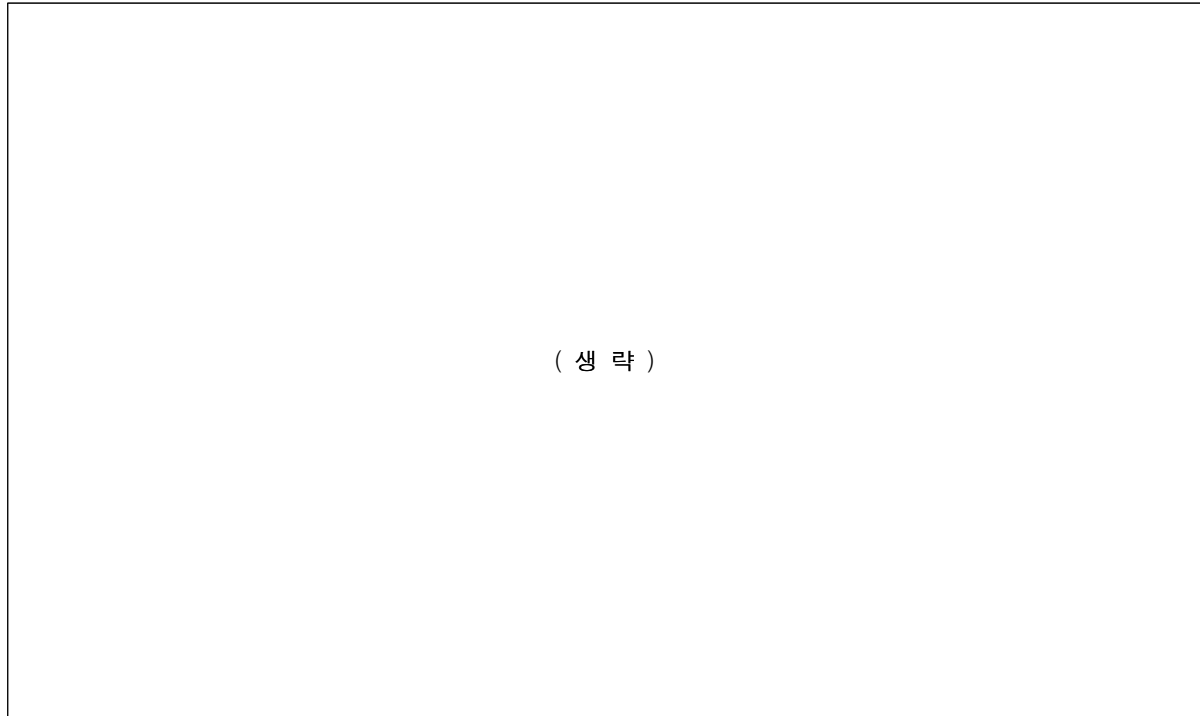
[그림 3] 자료이용신청서



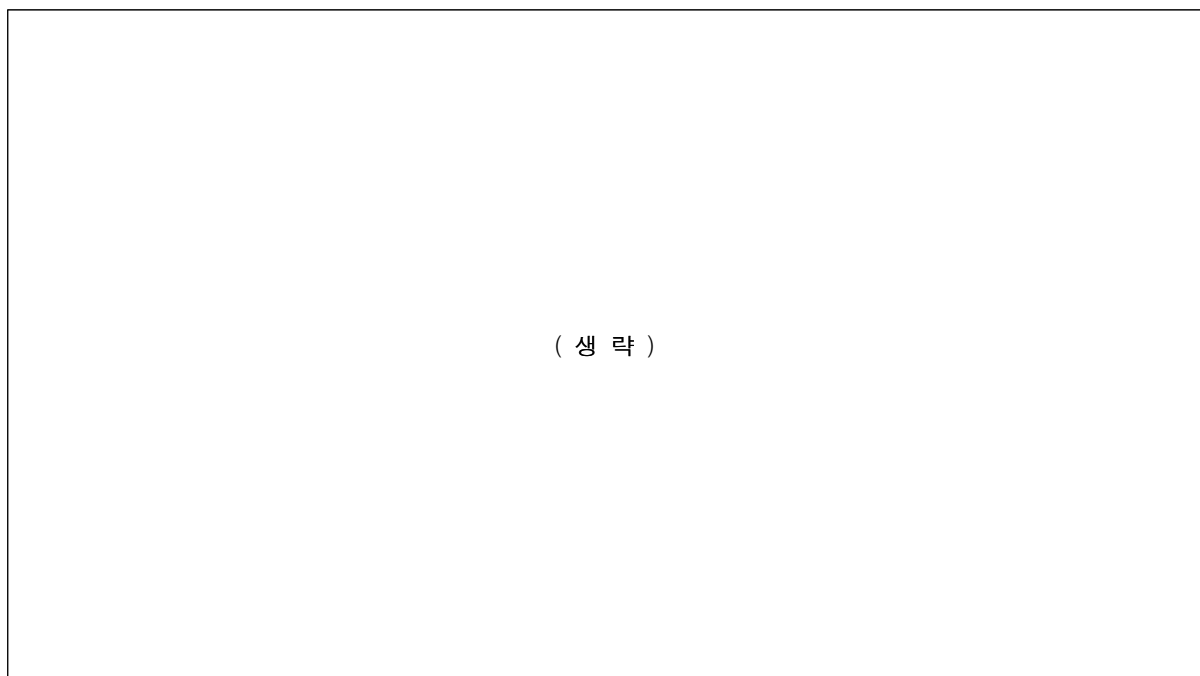
또한, 종료된 ☒호기 사업의 설계도면에 대해서도 조사를 수행한 결과, [그림 4]와 같이 ◆ 시스템상으로는 자료등급이 2급(특별보호자료)으로

표시되고 있으나, [그림 5]와 같이 웹브라우저 화면에서 HTML 소스코드⁵⁾를 확인하면 소스코드 내에서 사용자 권한을 결정하는 파라미터가 노출되어 있었다.

[그림 4] 종료사업의 자료등급 2급자료 조회



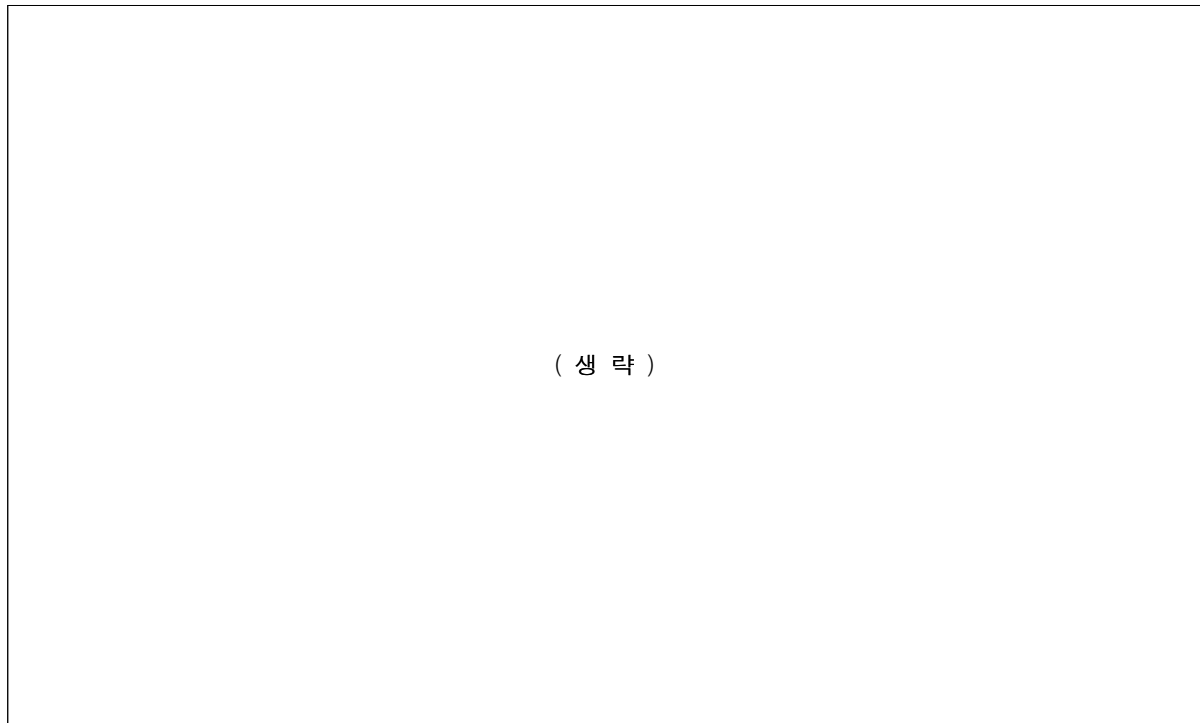
[그림 5] HTML 코드에서 사용자 권한 결정



5) 웹브라우저에서 마우스 오른쪽 클릭 → 메뉴에서 '소스 보기' 선택

실무자의 경우, 2급 자료는 열람만 가능하고 출력과 저장은 제한되어야 하나, HTML 소스 코드상의 권한 파라미터를 3급 자료를 의미하는 '3'으로 임의 변경⁶⁾하면, 시스템이 2급 자료를 3급 자료로 오인하여, [그림 6]와 같이 실무자도 2급 자료를 무단으로 출력할 수 있는 구조적 취약점이 존재한다.

[그림 6] 종료사업 자료등급 2급자료 출력물



그 결과, 현재 운영 중인 ◆ 시스템은 사업문서의 등급 관리가 「영업비밀보호관리규정」 및 TAP-00-00 절차서의 기준에 부합하지 않게 운영되고 있을 뿐만 아니라, 클라이언트 측에서 권한을 조작할 수 있는 구조로 인해 실무자가 2급(특별보호자료)에 해당하는 영업비밀 문서를 무단으로 출력 및 저장할 수 있는 중대한 보안 취약점이 존재한다.

6) ① 웹브라우저에서 키보드 'F12'키 클릭 → ② ◆ 웹브라우저 선택 → ③ 소스코드에서 해당 파라미터 변경하는 방법으로 HTML코드를 볼 수 있으면 쉽게 수정이 가능함. 대입 수험생들이 파라미터 변조로 2019년도 대입 수능 성적표를 사전 유출한 사례가 있었음(경향신문, 2019.12.2., 박채영 기자, '수능 성적표' 사전 유출 논란...평가원 보안 관리 '구명')

관계부서 의견 및 검토결과 ♠실은 감사 지적사항에 대해 업무 과실을 인정하며, 종료된 사업의 설계도면, 진행 중인 사업의 2급 자료가 4급 자료로 표시되어 출력된 원인에 대해 0000.0월 영업비밀 자료 등급 일괄 변경 과정에서 □시스템에서 발행된 설계 도면과 관련된 통합 View 생성 쿼리에서 자료 등급 변경 부분에 일부 누락이 발생하였다고 밝혔다.⁷⁾ 또한, 종료된 사업의 설계문서 2급 자료가 파라미터 변조로 출력되는 문제에 대해서는 서버에 확인 모듈이 없어서 발생하였다고 밝혔다.⁸⁾

① 양정에 고려할 사항

◆는 ♠실이 원활한 사업수행을 위해 0000년에 자체 개발한 시스템으로, 그동안 당사 인력으로만 유지보수 및 운영이 이루어져 왔다. 그러나 최근 전산 인력의 정년퇴직 및 이직 등으로 인해 전문 전산 인력이 부족한 상황이며, ㄴ장을 포함한 0명의 정보시스템 개발 인력으로 ◆ 시스템을 개발 및 유지보수를 수행하고 있다. 0명의 인력 중 ㄴ장을 제외한 0명은 개발 경력이 짧아 실무 숙련도가 낮은 상황이다. 이로 인해 시스템 개선보다는 설계 결과물이 적기에 생성될 수 있도록 하는 기능 유지와 지원에 최우선 순위를 두고 관련 업무를 수행하고 있다.

또한, 감사과정에서 ♠실에서 제출한 종료사업의 자료 이용 목록을 확인한

7) 0000.00.0. 문답확인서 “

(답 0-0, 0-0)

- 00년 0월 영업 비밀 자료 등급 일괄 변경 시, □시스템에서 발행된 설계 도면과 관련한 통합 View 생성 쿼리에서 자료 등급 변경 부분이 일부 누락됨.
- 따라서, 검색 화면에서 보여지는 자료 등급 표기 컬럼은 정상 변경 되었으나, 첨부파일 열람 시 참조하는 자료 등급 정보의 변경이 누락되어 상기의 상황이 발생되었음.”

8) 0000.00.0. 문답확인서 “

(답 0-0)

- o 요청모듈에서 호출하는 자료등급을 회사 PDF 보안 솔루션(※)에 전달하여 호출함
- o 기존에는 서버 확인 모듈 없음”

결과 실무자가 2급 이상 자료를 무단으로 출력 및 저장한 이력은 있으나 데이터 유출 등 영업비밀 침해 등 실질적인 피해가 발생하지 않은 것으로 파악되었으며, 2급 자료가 4급 자료로 출력되는 문제는 감사실 지적 이후 0000.0.00.에 긴급히 조치 완료하였고⁹⁾, 2급 자료가 파라미터 변조로 출력되는 문제도 0000.0.00.에 조치 완료¹⁰⁾한 점 등을 고려할 필요가 있다.

② 신분상 처분의 결정

♠실은 「영업비밀보호관리규정」 및 기술업무절차서에 위반되는 내용으로 ◆ 시스템을 운영한 결과, 회사의 중요 사업문서 관리에 보안 취약성이 발생하였기에, 피감부서에 경각심을 주고, 향후 동일 사례 재발 방지를 위한 적절한 신분상의 조치가 요구된다.

다만, 본 건 지적사항과 관련하여 데이터 유출로 인한 영업비밀 침해 등 회사에 실질적인 피해가 발생하지 않았으며, 피감부서인 ♠실의 부서장 및 실무 책임자인 ㄴ장에게 고의 및 중과실은 없었던 것으로 판단되어 ‘경고’를 요구하기로 결정하였다. 그러나 피감사인 모두 적극행정면책을 신청하였고, 감사심의위원회를 통해 면책 결정을 인용하였으며, 이에 따라 피감사인에게 ‘주의’ 처분하는 것으로 최종 결정하였다.

9) 0000.00.0. 문답확인서 “

(답 0-0, 0-0)

○ 조치 내용 (조치완료함.0.00)

- 해당 View 테이블(x_xx_XXXXXXX_xxx)의 생성 쿼리를 수정하여 조치하였음.”

10) 0000.00.0. 문답확인서 “

(답 0-0)

○ 조치 완료함 (조치일 : 0000.0.00)

○ 조치 내용

- 파라미터 호출 시, 자료 등급 암호화/복호화 적용”

조치할 사항

① 「영업비밀보호관리규정」 및 기술업무절차서 「사업문서 등급 및 이용 관리」의 분류 기준과 맞지 않게 운영한 ♠부장 H와 ♠실 Ⅲ부장 I에게 경각심을 고취시키고 향후 동일사례가 발생하지 않도록 주의를 촉구합니다. 【주의】

♠실장은

② 「영업비밀보호관리규정」 및 기술업무절차서 「사업문서 등급 및 이용 관리」의 분류 기준에 맞게 ◆ 시스템 내 자료의 등급 표시 및 관리가 일관되게 조치하시기 바랍니다. 【시정】

③ 영업비밀 등급 지정 로직을 서버 측에서 처리하도록 ◆ 시스템을 변경하여, 클라이언트 측 입력값이 보안 결정에 영향을 미치지 않도록 조치하시기 바랍니다. 【시정】